

UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación

Curso: Seguridad y Auditoría de Sistemas

Catedrático: Ing. _____

PROYECTO DE CURSO — DOCUMENTO FINAL

Modelo integral de seguridad y auditoría para la infraestructura tecnológica de la Clínica Médica Vida Segura

Implementación virtualizada con VMware y Windows Server

Integrante	Carné
Edgar Javier Nij Manchame	9490-19-11174
Byron Geovanni Chicoj Perez	____-____-____
Christian Aldair Rosales	____-____-____

Guatemala, septiembre de 2026

Índice

Índice.....	1
Introducción.....	2
1. Modelo de Negocio.....	3
1.1 Planteamiento del problema (situación actual).....	3
1.2 Objetivos.....	3
Objetivo general.....	3
Objetivos específicos.....	3
1.3 Planificación de la solución.....	4
2. Modelo de Seguridad.....	5
2.1 Planteamiento del proyecto de seguridad.....	5
2.2 Viabilidad técnica y operativa de la solución.....	5
Viabilidad técnica.....	5
Viabilidad operativa.....	5
Viabilidad económica.....	5
2.3 Contexto técnico de trabajo.....	6
2.3.1 Hardware.....	6
2.3.2 Software.....	6
2.3.3 Metodología y estándar.....	7
2.4 Otros recursos y consideraciones.....	7
2.5 Plan de ejecución.....	7
2.6 Clasificación de vulnerabilidades y amenazas.....	8
2.7 Implementación del estándar ISO/IEC 27001/27002.....	9
2.7.1 Autenticación centralizada con Active Directory.....	9
2.7.2 Unión de estaciones al dominio.....	12
2.7.3 Política de contraseñas y bloqueo de cuentas.....	15
2.7.4 Bloqueo automático de sesión (GPO_SEGURIDAD_CLINICA).....	16
2.7.5 Control de acceso a expedientes (NTFS y recurso compartido).....	17
2.7.6 Auditoría de acceso a objetos (eventos 4663).....	18
2.7.7 Auditoría de bloqueo de cuentas (evento 4740).....	22
2.7.8 Auditoría de cambios en grupos de seguridad (evento 4728).....	24
2.7.9 Respaldo y recuperación con Windows Server Backup.....	25
2.7.10 Resumen de eventos auditable.....	30
Conclusiones y recomendaciones.....	32
Conclusiones.....	32
Recomendaciones.....	32
Glosario.....	33
Bibliografía.....	34
Anexo. Acceso al proyecto virtualizado.....	35

Introducción

El presente documento reúne el proyecto de curso de Seguridad y Auditoría de Sistemas. Se tomó como modelo de negocio la Clínica Médica Vida Segura, una clínica privada que atiende pacientes particulares y que maneja información muy sensible: datos personales, expedientes clínicos, diagnósticos, recetas y la agenda de citas.

En el segundo entregable se planteó la arquitectura de seguridad objetivo de la clínica (defensa en profundidad, control de acceso por roles, cifrado, bitácoras y respaldos) alineada a la familia ISO/IEC 27000. En esta etapa final esa propuesta se llevó a la práctica: se construyó un laboratorio virtual en VMware con un servidor Windows Server y dos estaciones de trabajo que representan el consultorio médico y la recepción, y sobre él se implementaron y probaron los controles.

Cada control implementado deja evidencia en el registro de seguridad del servidor (eventos 4663, 4740 y 4728), por lo que el modelo es auditable: un auditor puede verificar quién accedió a qué información, cuándo y desde qué equipo. El documento sigue la estructura solicitada por el catedrático e incluye, en la sección 2.4 y en el anexo, el enlace al sitio donde está alojado y documentado el proyecto.

1. Modelo de Negocio

Clínica Médica Vida Segura es una organización de servicios de salud que brinda consulta médica a pacientes particulares. Su operación diaria gira alrededor de tres áreas: recepción (registro de pacientes y citas), consultorios (atención médica y expediente clínico) y administración (dirección, reportes y finanzas).

Rol	Función en el negocio	Relación con la información
Administrador de la clínica	Dirige la operación y aprueba las políticas.	Reportes administrativos; dueño de las políticas.
Médico	Atiende pacientes y actualiza el expediente.	Lectura y escritura del expediente clínico.
Recepción	Registra pacientes y agenda citas.	Datos demográficos y agenda; sin acceso a diagnósticos.
Administrador de sistemas	Gestiona usuarios, servidor, respaldos y controles.	Administración técnica; sin uso del contenido clínico.

1.1 Planteamiento del problema (situación actual)

Antes del proyecto, la clínica trabajaba con equipos independientes y cuentas locales. Esto genera los siguientes problemas:

- No existe una autenticación centralizada: cada computadora tiene sus propios usuarios y contraseñas, a veces compartidas entre el personal.
- Cualquier persona con acceso a una computadora puede abrir los expedientes clínicos, incluida la recepción, que no los necesita para su trabajo.
- No hay registro de quién consulta o modifica un expediente, por lo que ante una fuga o alteración no se puede determinar el responsable.
- Las sesiones quedan abiertas cuando el personal se levanta del equipo.
- No hay política de contraseñas ni bloqueo por intentos fallidos, lo que facilita ataques de fuerza bruta.
- No existen respaldos programados; un borrado accidental o un ataque de ransomware puede provocar la pérdida definitiva de expedientes.

El sector salud es de los más atacados por ransomware y robo de credenciales, y un expediente médico es información de carácter confidencial. Por eso la clínica necesita un modelo de seguridad que controle el acceso, deje trazabilidad y garantice la recuperación de la información.

1.2 Objetivos

Objetivo general

Implementar un modelo de seguridad de la información auditable para la Clínica Médica Vida Segura, que proteja la confidencialidad, integridad y disponibilidad de los expedientes y datos de pacientes, tomando como referencia la norma ISO/IEC 27001/27002.

Objetivos específicos

- Centralizar la autenticación de usuarios y equipos mediante un dominio de Active Directory.

- Aplicar control de acceso basado en roles (grupos) y el principio de mínimo privilegio sobre los expedientes clínicos.
- Definir políticas de contraseñas, bloqueo de cuentas y bloqueo automático de sesión mediante directivas de grupo (GPO).
- Configurar la auditoría de accesos, bloqueos de cuenta y cambios en grupos de seguridad para contar con trazabilidad.
- Implementar respaldos en un disco dedicado y comprobar la recuperación de información eliminada.
- Documentar y publicar el entorno virtualizado para su revisión y auditoría.

1.3 Planificación de la solución

La solución se planificó en tres niveles: primero el análisis del negocio y sus activos, luego el diseño de la arquitectura de seguridad (segundo entregable) y finalmente la implementación en un laboratorio virtual que reproduce la red de la clínica.

Fase	Actividades	Resultado
Análisis	Identificación de roles, inventario y clasificación de activos.	Inventario de activos y matriz de roles.
Diseño	Arquitectura por capas, matriz RBAC, matriz de riesgos, alineación ISO/IEC 27000.	Segundo entregable.
Implementación	Montaje del laboratorio en VMware; AD, DNS, GPO, NTFS, auditoría y respaldos.	Controles funcionando con evidencia.
Pruebas y auditoría	Pruebas de acceso permitido/denegado, bloqueo, cambios de grupo y restauración.	Eventos registrados y verificados.
Publicación	Exportación de las VM, sitio web del proyecto y documento final.	Enlace al proyecto alojado.

2. Modelo de Seguridad

2.1 Planteamiento del proyecto de seguridad

El proyecto consiste en montar la infraestructura tecnológica de la clínica sobre un dominio de Windows Server y aplicar sobre ella controles de seguridad preventivos, detectivos y de recuperación. El enfoque es de defensa en profundidad: la seguridad no depende de un solo mecanismo, sino de varias capas que se complementan.

Pilar (tríada CIA)	Controles implementados
Confidencialidad	Active Directory, grupos por rol, permisos NTFS, bloqueo automático de sesión.
Integridad	Solo GG_MEDICOS puede modificar expedientes; auditoría de accesos y de cambios en grupos.
Disponibilidad	Respaldo con Windows Server Backup en disco dedicado y procedimiento de recuperación probado.

El alcance del laboratorio cubre la capa de identidad, acceso a datos, auditoría y continuidad. Los componentes del segundo entregable orientados a la aplicación web (cifrado TLS, firewall perimetral pfSense, segmentación en VLAN) se mantienen como parte de la arquitectura objetivo y se describen en las recomendaciones.

2.2 Viabilidad técnica y operativa de la solución

Viabilidad técnica

La solución es técnicamente viable porque utiliza servicios que ya incluye Windows Server (AD DS, DNS, directivas de grupo, auditoría y Windows Server Backup), sin necesidad de licencias adicionales de terceros. El laboratorio demostró que los controles funcionan con recursos modestos: el servidor opera con 2 GB de RAM y un disco de sistema de 20 GB más un disco de respaldo de 5 GB. En producción se recomienda un servidor físico o virtual con mayores recursos.

Viabilidad operativa

Para el personal de la clínica los cambios son transparentes: cada persona inicia sesión con su usuario del dominio y ve únicamente lo que le corresponde. La administración también se simplifica, ya que para dar acceso a un nuevo médico basta con agregar su usuario al grupo GG_MEDICOS. Las políticas se aplican de forma automática desde el servidor, sin configurar equipo por equipo.

Viabilidad económica

Concepto	Costo aproximado
Servidor para la clínica	Q6,000
Equipo dedicado para firewall	Q2,000
Configuración de servidor e infraestructura de red	Q2,500
Implementación de controles de seguridad	Q3,000
Sistema de respaldo	Q1,500
Capacitación y documentación	Q1,000

Concepto	Costo aproximado
TOTAL ESTIMADO	Q16,000

Nota: el costo de licencias de Windows Server y Windows 10/11 Pro depende del canal de compra y no está incluido. En el laboratorio se usaron versiones de evaluación.

2.3 Contexto técnico de trabajo

El modelo de seguridad se aplica sobre la red interna de la clínica, representada en el laboratorio por la red LAN_CLINICA (192.168.10.0/24), con un servidor central y dos estaciones de trabajo.

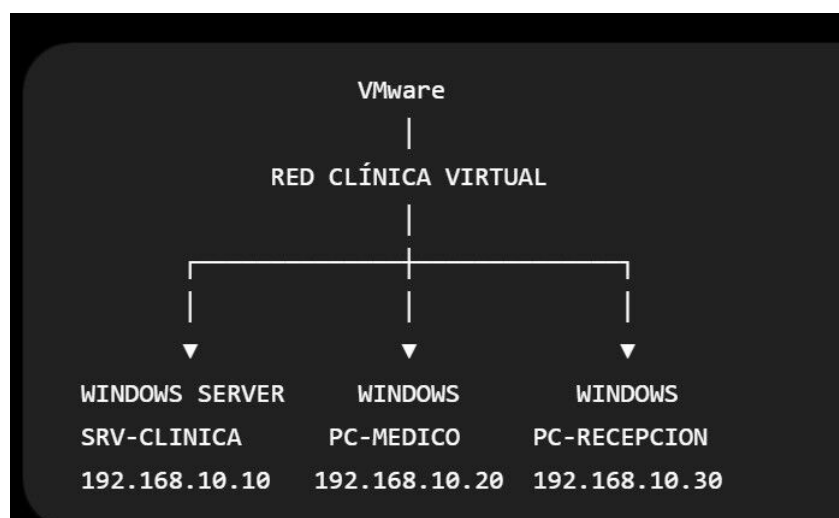


Figura 1. Topología de la red clínica virtual en VMware.

2.3.1 Hardware

Equipo	Recursos	IP	Función
Equipo anfitrión	PC del equipo de trabajo con VMware Workstation (recomendado: 16 GB RAM, CPU con virtualización)	—	Ejecuta las tres máquinas virtuales
SRV-CLINICA (VM)	2 GB RAM · Disco 0: 20 GB (sistema) · Disco 1: 5 GB (BACKUP_CLINICA)	192.168.10.10	Controlador de dominio, DNS, archivos, auditoría, respaldos
PC-MEDICO (VM)	Adaptador Intel 82574L en LAN_CLINICA	192.168.10.20	Estación del consultorio
PC-RECEPCION (VM)	Adaptador en LAN_CLINICA	192.168.10.30	Estación de recepción

2.3.2 Software

Software	Uso en el proyecto
VMware Workstation	Virtualización de las tres máquinas y de la red LAN_CLINICA.
Windows Server 2022 Datacenter (Evaluation)	Sistema operativo del servidor SRV-CLINICA.
Active Directory Domain Services + DNS	Dominio clinica.local, usuarios, grupos, OU y resolución de nombres.

Software	Uso en el proyecto
Administración de directivas de grupo (GPMC)	Default Domain Policy, GPO_SEGURIDAD_CLINICA y GPO_AUDITORIA_SERVIDOR.
Visor de eventos	Revisión de los eventos de seguridad 4663, 4740 y 4728.
Copias de seguridad de Windows Server (wbadmin)	Respaldo y recuperación de CLINICA_DATOS.
Windows 10 Enterprise (Evaluation)	Sistema operativo de PC-MEDICO y PC-RECEPCION.
Firewall de Windows Defender / Microsoft Defender	Protección de red y antimalware en servidor y estaciones.

2.3.3 Metodología y estándar

Se tomó como marco de referencia la norma ISO/IEC 27001:2022 (sistema de gestión de seguridad de la información) y su guía de controles ISO/IEC 27002:2022. El trabajo siguió el ciclo PDCA (Planificar-Hacer-Verificar-Actuar) que propone la norma:

- **Planificar:** inventario de activos, análisis de riesgos y selección de controles (segundo entregable).
- **Hacer:** implementación de los controles en el laboratorio virtual.
- **Verificar:** pruebas de acceso permitido y denegado, revisión de eventos de auditoría y prueba de restauración.
- **Actuar:** ajustes y recomendaciones de mejora para la implementación real.

Como apoyo se consideraron el NIST Cybersecurity Framework 2.0 (funciones Gobernar, Identificar, Proteger, Detectar, Responder y Recuperar) y las buenas prácticas de Microsoft para la auditoría de Active Directory.

2.4 Otros recursos y consideraciones

- Recurso humano: tres integrantes con funciones de arquitectura y documentación, infraestructura y red, y configuración de controles y auditoría.
- Las credenciales del laboratorio (medico01, recepcion01, Admin01) son solo para pruebas. En producción deben reemplazarse por contraseñas robustas y únicas.
- Las versiones de evaluación de Windows tienen vigencia limitada (180 días para Windows Server y 90 días para Windows 10 Enterprise).
- Los registros de seguridad deben conservarse con un tamaño adecuado del registro de eventos para no perder evidencia.
- El personal debe recibir una capacitación breve sobre el uso de su cuenta, el bloqueo de sesión y la política de contraseñas.

Acceso al proyecto alojado: el entorno virtualizado, las evidencias y las máquinas virtuales exportadas se encuentran publicados en <https://USUARIO.github.io/clinica-vida-segura/>.

2.5 Plan de ejecución

N.º	Actividad	Duración	Responsable
1	Levantamiento de requerimientos e inventario de activos	1 semana	Todo el equipo
2	Análisis de riesgos	1 semana	E. Nij
3	Diseño de arquitectura y políticas	1 semana	E. Nij

N.º	Actividad	Duración	Responsable
4	Preparación del laboratorio: VMware, red LAN_CLINICA, instalación de SO	1 semana	B. Chicoj
5	AD DS, DNS, OU, usuarios, grupos y unión de equipos al dominio	1 semana	B. Chicoj
6	GPO de contraseñas, bloqueo de cuenta y de pantalla; permisos NTFS	1 semana	C. Rosales
7	Auditoría (4663, 4740, 4728) y respaldo/recuperación	1 semana	C. Rosales
8	Pruebas, publicación del sitio y documento final	1 semana	Todo el equipo
	TOTAL	8 semanas	

2.6 Clasificación de vulnerabilidades y amenazas

Se clasificaron las amenazas según su origen y se valoró el riesgo combinando probabilidad e impacto (bajo, medio, alto). Para cada una se indica el control aplicado en el proyecto.

Amenaza	Tipo	Vulnerabilidad	Prob.	Impacto	Riesgo	Control
Acceso no autorizado a expedientes	Amenaza humana interna	Permisos amplios, sin roles	Media	Alto	Alto	Grupos AD + NTFS + auditoría 4663
Robo o adivinación de contraseñas	Amenaza humana externa/interna	Contraseñas débiles, sin bloqueo	Alta	Alto	Alto	Política de contraseñas + bloqueo (4740)
Uso de sesión abierta por otra persona	Amenaza humana interna	Equipos sin bloqueo automático	Alta	Medio	Alto	GPO bloqueo de pantalla 1 min
Escalada de privilegios (agregar usuarios a grupos)	Amenaza humana interna	Cambios sin registro	Baja	Alto	Medio	Auditoría de cambios en grupos (4728)
Borrado accidental de expedientes	Error humano	Sin respaldos	Media	Alto	Alto	Windows Server Backup en disco dedicado
Ransomware / malware	Amenaza técnica externa	Equipos sin protección y sin respaldo	Media	Alto	Alto	Antimalware, firewall y respaldo aislado
Falla del disco del servidor	Amenaza física / técnica	Un solo punto de almacenamiento	Baja	Alto	Medio	Respaldo en segundo disco y copia externa
Intercepción de tráfico en la red	Amenaza técnica	Red plana sin segmentar	Baja	Medio	Bajo	Firewall de Windows, segmentación futura (VLAN)

Los activos más críticos son el expediente clínico electrónico y los datos personales del paciente (confidenciales), seguidos de las credenciales y los registros de auditoría (restringidos) y los respaldos (confidenciales).

2.7 Implementación del estándar ISO/IEC 27001/27002

La siguiente tabla relaciona los controles del Anexo A de ISO/IEC 27001:2022 (descritos en ISO/IEC 27002:2022) con lo implementado en el laboratorio. A continuación se presenta la evidencia de cada implementación.

Control ISO/IEC 27002:2022	Implementación en la clínica
5.15 Control de acceso	Matriz por roles; acceso a Expedientes solo para GG_MEDICOS
5.16 Gestión de identidades	Usuarios nominales en el dominio clinica.local
5.17 Información de autenticación	Política de contraseñas del dominio
5.18 Derechos de acceso	Alta de permisos por grupos; auditoría de cambios (4728)
7.7 Escritorio y pantalla limpios	GPO de bloqueo de pantalla por inactividad
8.2 Derechos de acceso privilegiado	Cuentas de administración separadas de las operativas
8.3 Restricción de acceso a la información	Permisos NTFS sobre C:\CLINICA_DATOS\Expedientes
8.5 Autenticación segura	Bloqueo de cuenta tras 5 intentos fallidos
8.13 Respaldo de la información	Windows Server Backup en disco dedicado; restauración probada
8.15 Registro (logging)	Auditoría de sistema de archivos y de cuentas
8.16 Actividades de monitoreo	Revisión de eventos 4663, 4740 y 4728 en el Visor de eventos
8.7 Protección contra malware	Microsoft Defender en servidor y estaciones

2.7.1 Autenticación centralizada con Active Directory

Se promovió SRV-CLINICA como controlador del dominio clinica.local con el rol DNS integrado. Se creó la unidad organizativa CLINICA con las OU Usuarios (Medicos, Recepcion, Administracion) y Equipos, y los grupos globales GG_MEDICOS, GG_RECEPCION y GG_ADMINISTRACION. Los permisos se asignan a los grupos y no a los usuarios individuales, lo que permite aplicar control de acceso basado en roles.

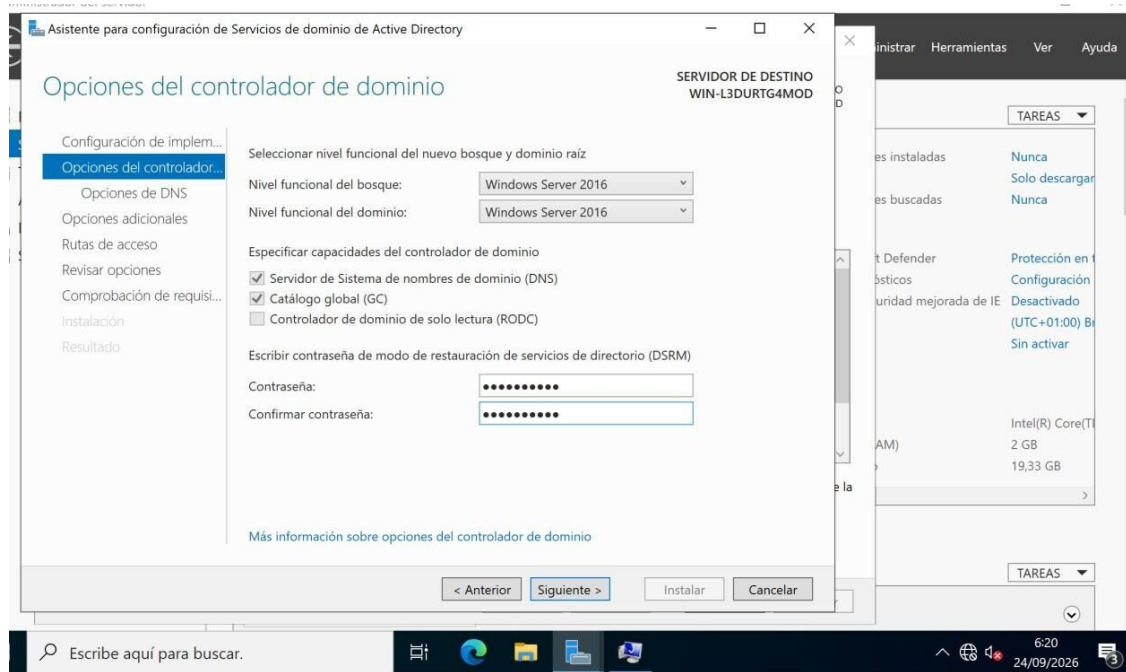


Figura 2. Asistente de configuración de AD DS: nuevo bosque clinica.local con servidor DNS y catálogo global.

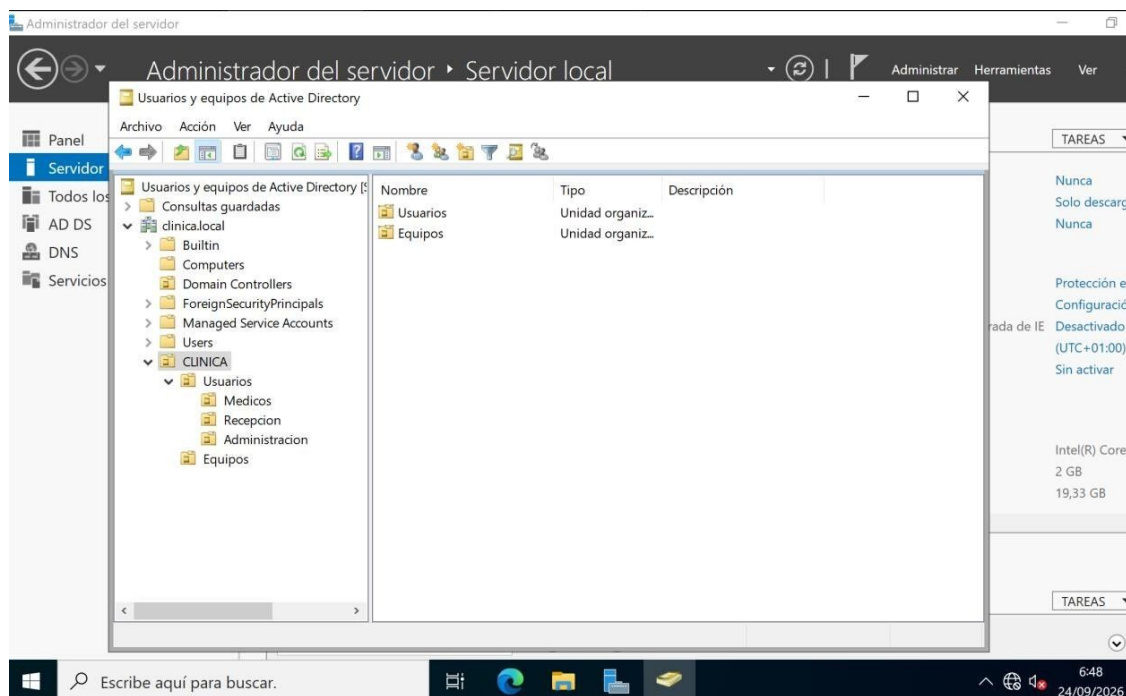


Figura 3. Estructura de unidades organizativas del dominio: CLINICA > Usuarios (Medicos, Recepcion, Administracion) y Equipos.

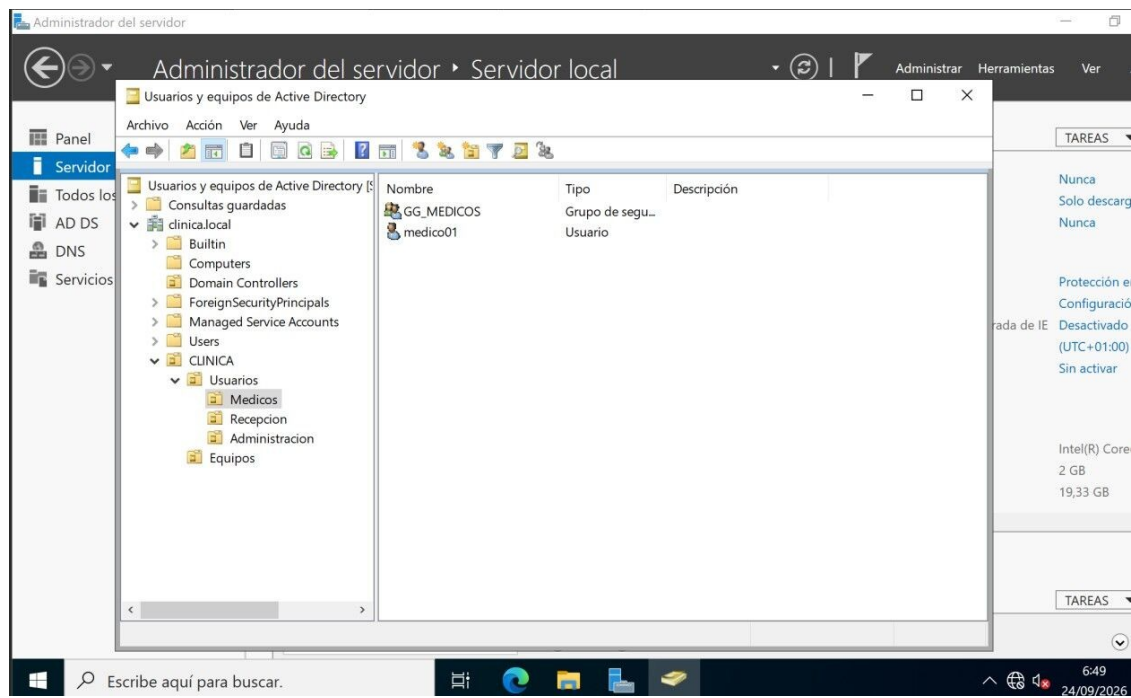


Figura 4. OU Medicos con el grupo GG_MEDICOS y el usuario medico01.

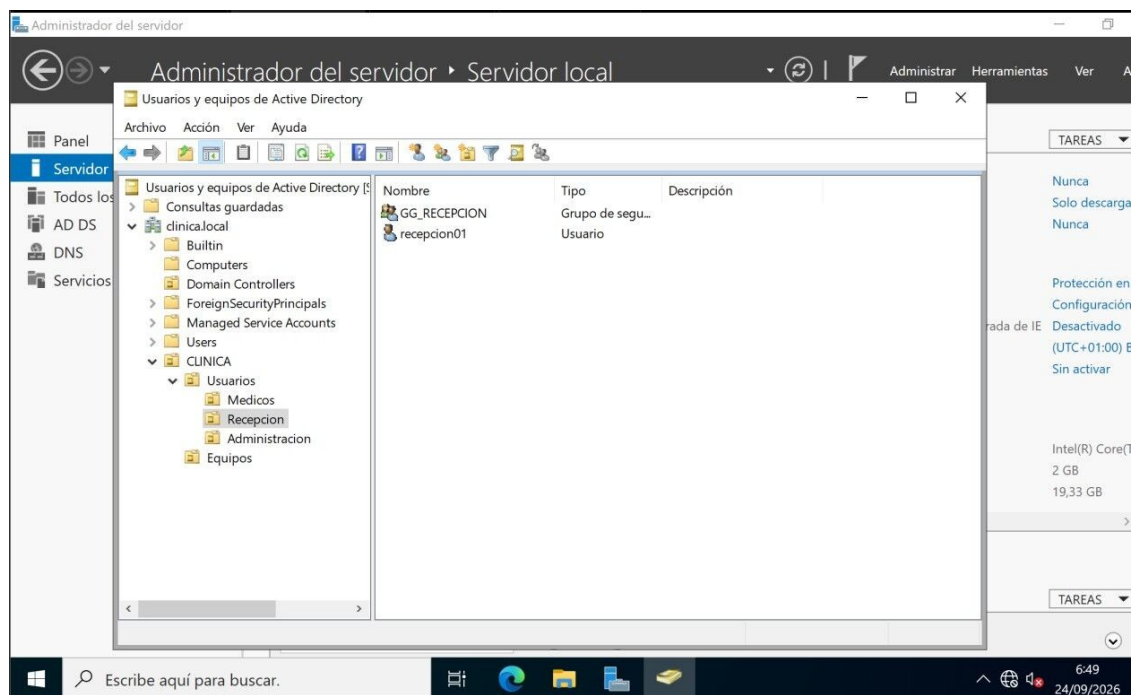


Figura 5. OU Recepcion con el grupo GG_RECEPCION y el usuario repcion01.

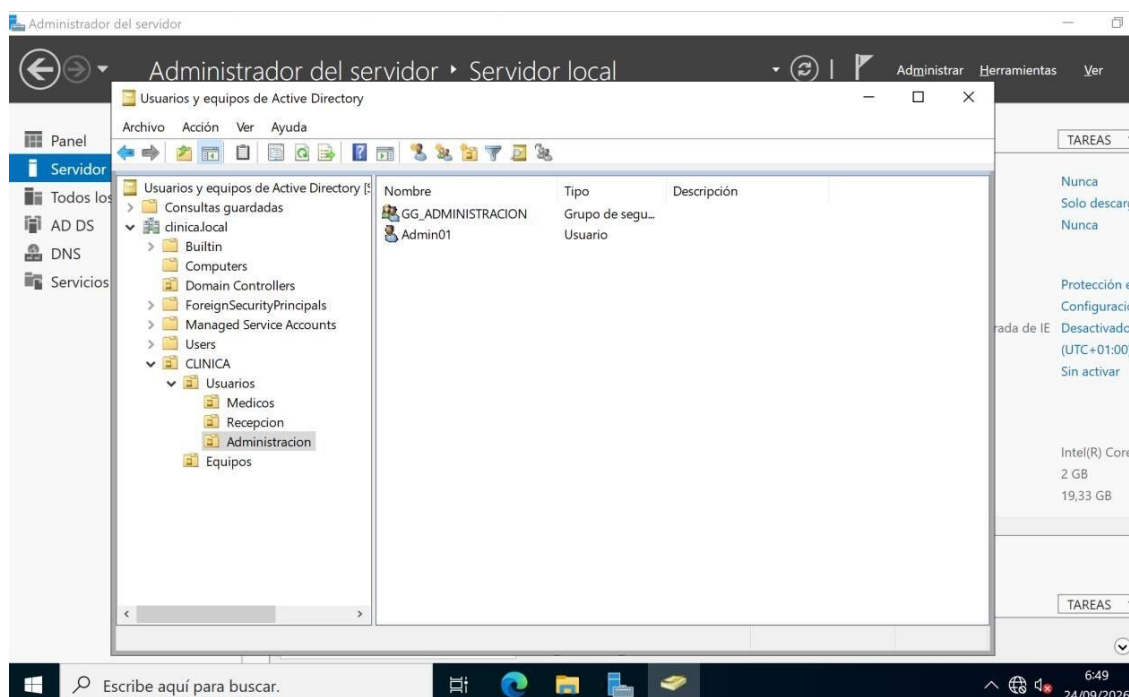


Figura 6. OU Administracion con el grupo GG_ADMINISTRACION y el usuario Admin01.

2.7.2 Unión de estaciones al dominio

Las estaciones PC-MEDICO y PC-RECEPCION se configuraron con IP fija en la red 192.168.10.0/24 y con el servidor como DNS. Se comprobó la conectividad y la resolución del dominio antes de unir las. Desde ese momento los usuarios inician sesión con cuentas del dominio y no con cuentas locales.

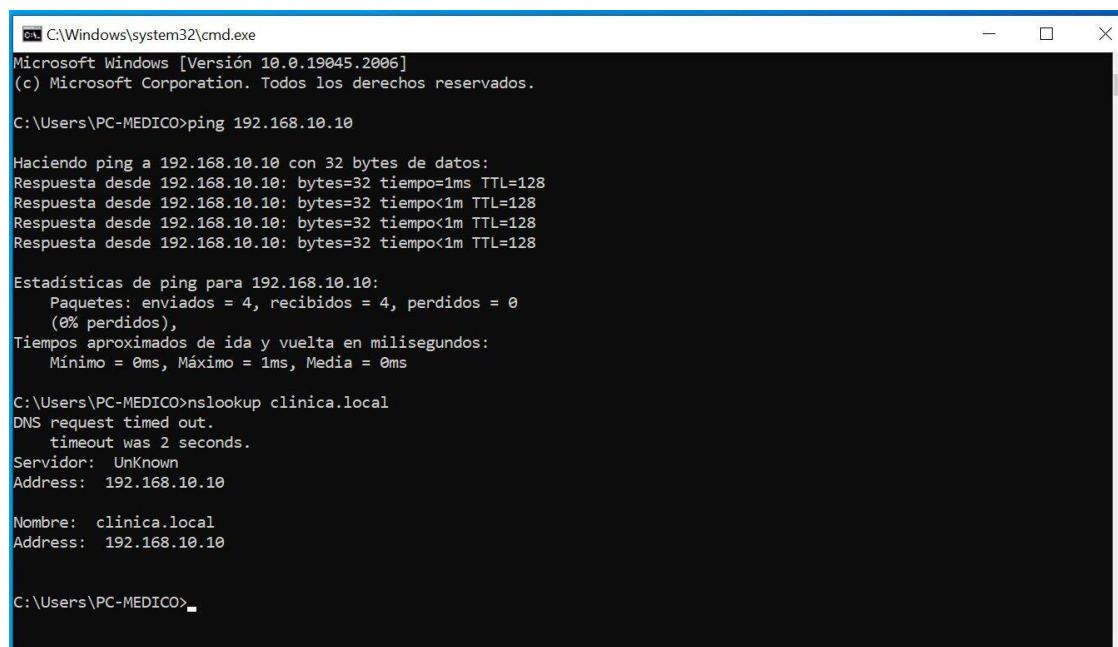


Figura 7. Prueba de conectividad (ping) y resolución DNS de clinica.local desde PC-MEDICO.

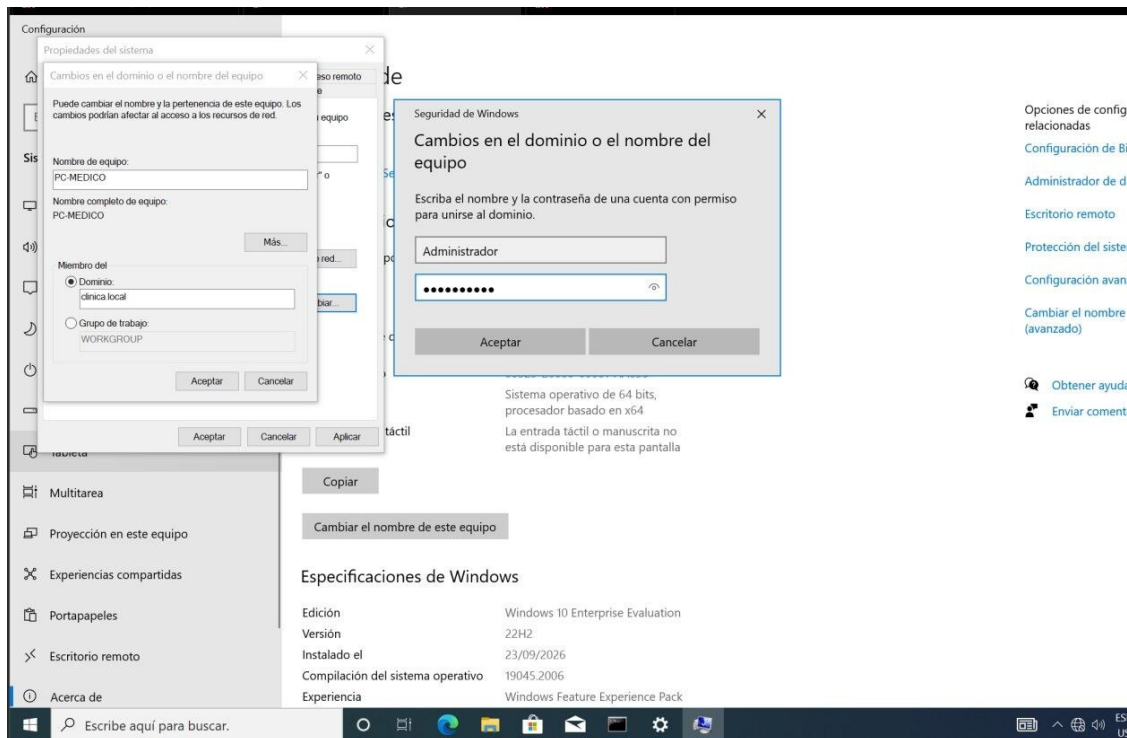


Figura 8. Unión de PC-MEDICO al dominio clinica.local con credenciales de administrador.

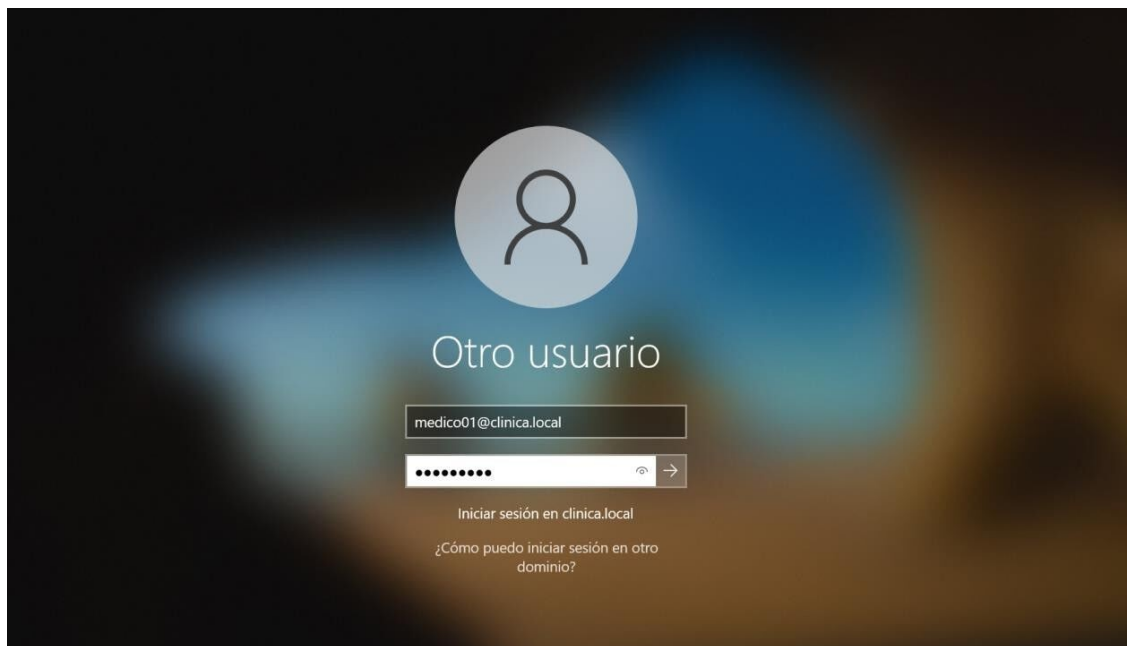


Figura 9. Inicio de sesión en PC-MEDICO con la cuenta de dominio medico01@clinica.local.

```

C:\Windows\system32\cmd.exe
> ipconfig /allcompartments /all ... Muestra información detallada sobre
                                los compartimientos.
                                todos los compartimientos

C:\Users\medico01>ipconfig /all

Configuración IP de Windows

Nombre de host. . . . . : PC-MEDICO
Sufijo DNS principal . . . . : clinica.local
Tipo de nodo. . . . . : híbrido
Enrutamiento IP habilitado. . . : no
Proxy WINS habilitado . . . . : no
Lista de búsqueda de sufijos DNS: clinica.local

Adaptador de Ethernet Ethernet0:

Sufijo DNS específico para la conexión. . :
Descripción . . . . . : Intel(R) 82574L Gigabit Network Connection
Dirección física. . . . . : 00-0C-29-47-6F-A8
DHCP habilitado . . . . . : no
Configuración automática habilitada . . . : sí
Dirección IPv4. . . . . : 192.168.10.20(Preferido)
Máscara de subred . . . . . : 255.255.255.0
Puerta de enlace predeterminada . . . . : 192.168.10.10
Servidores DNS. . . . . : 192.168.10.10
                                192.168.10.40
NetBIOS sobre TCP/IP. . . . . : habilitado

C:\Users\medico01>

```

Figura 10. `ipconfig /all` en PC-MEDICO: IP 192.168.10.20, DNS 192.168.10.10 y sufijo clinica.local.

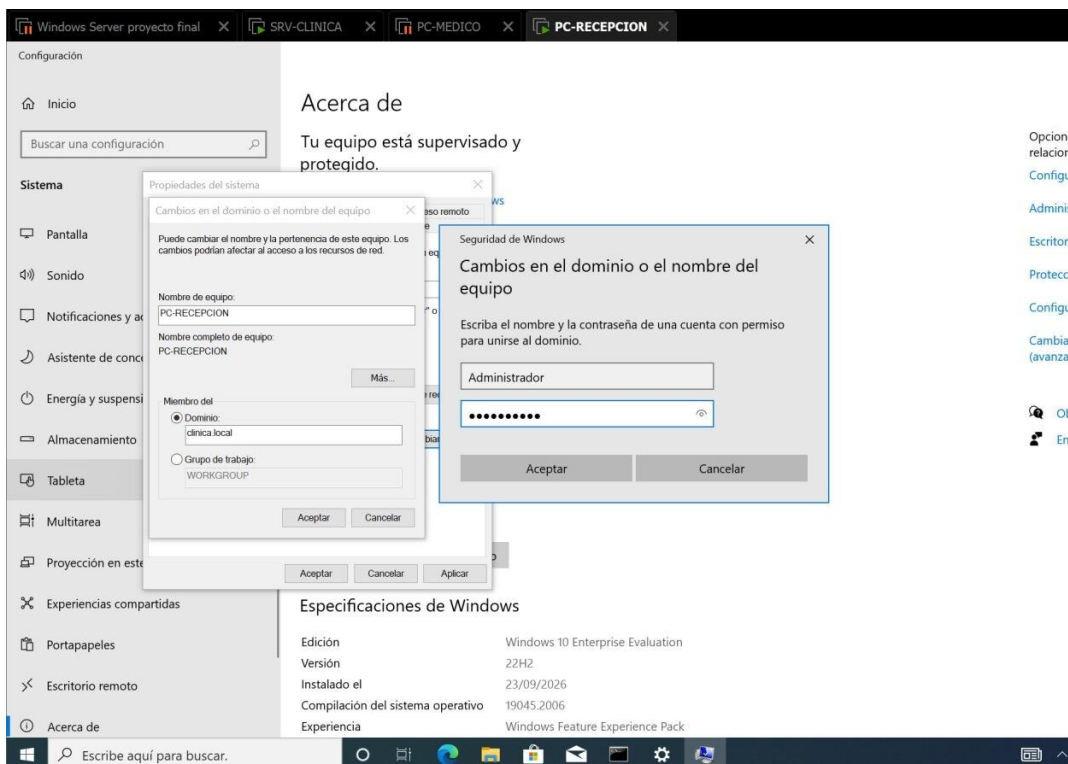


Figura 11. Unión de PC-RECEPCION al dominio clinica.local.

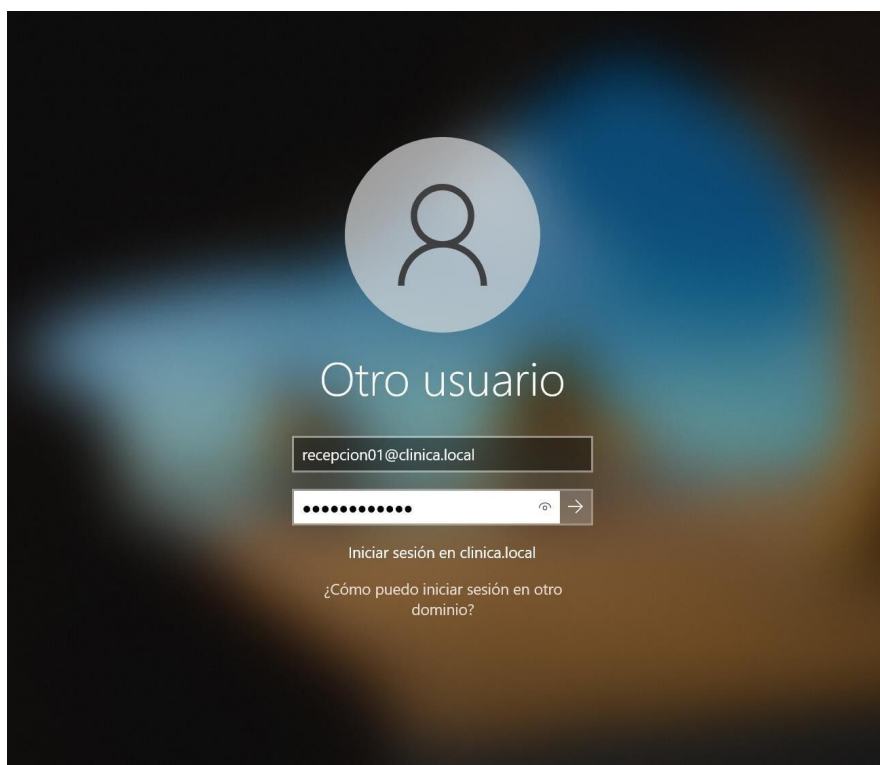


Figura 12. Inicio de sesión en PC-RECEPCION con la cuenta recepcion01@clinica.local.

2.7.3 Política de contraseñas y bloqueo de cuentas

En la Default Domain Policy se definió la política de contraseñas (longitud mínima de 7 caracteres, complejidad habilitada, historial de 5 contraseñas, vigencia máxima de 42 días y mínima de 1 día) y la política de bloqueo: la cuenta se bloquea después de 5 intentos fallidos durante 2 minutos.

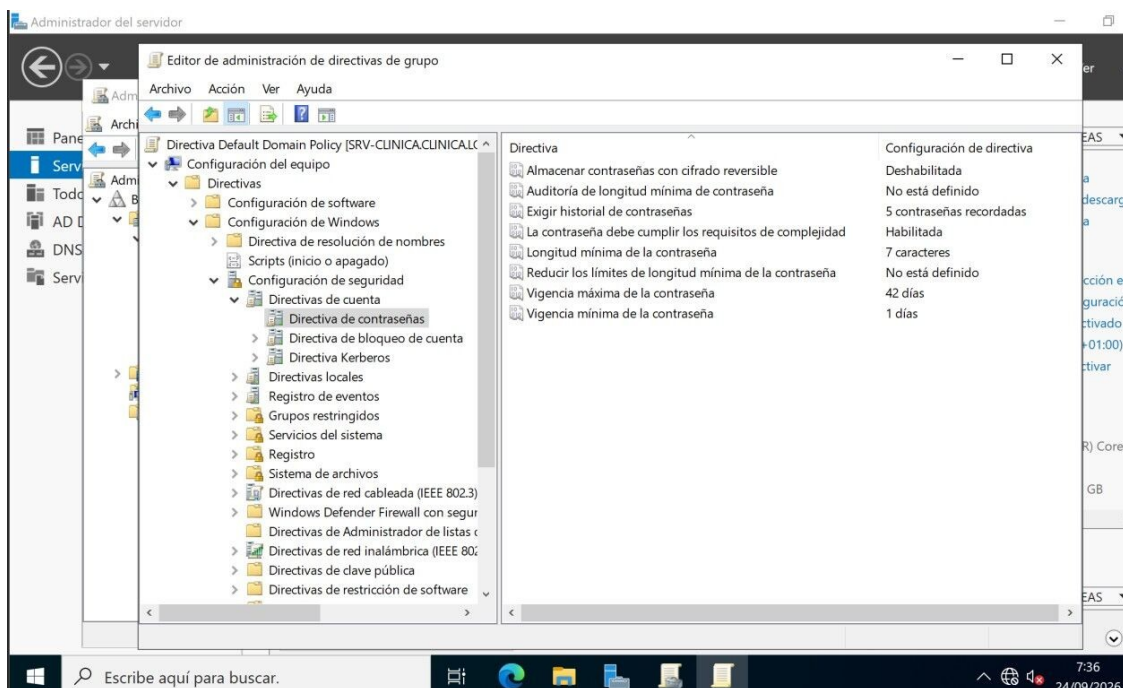


Figura 13. Directiva de contraseñas del dominio.

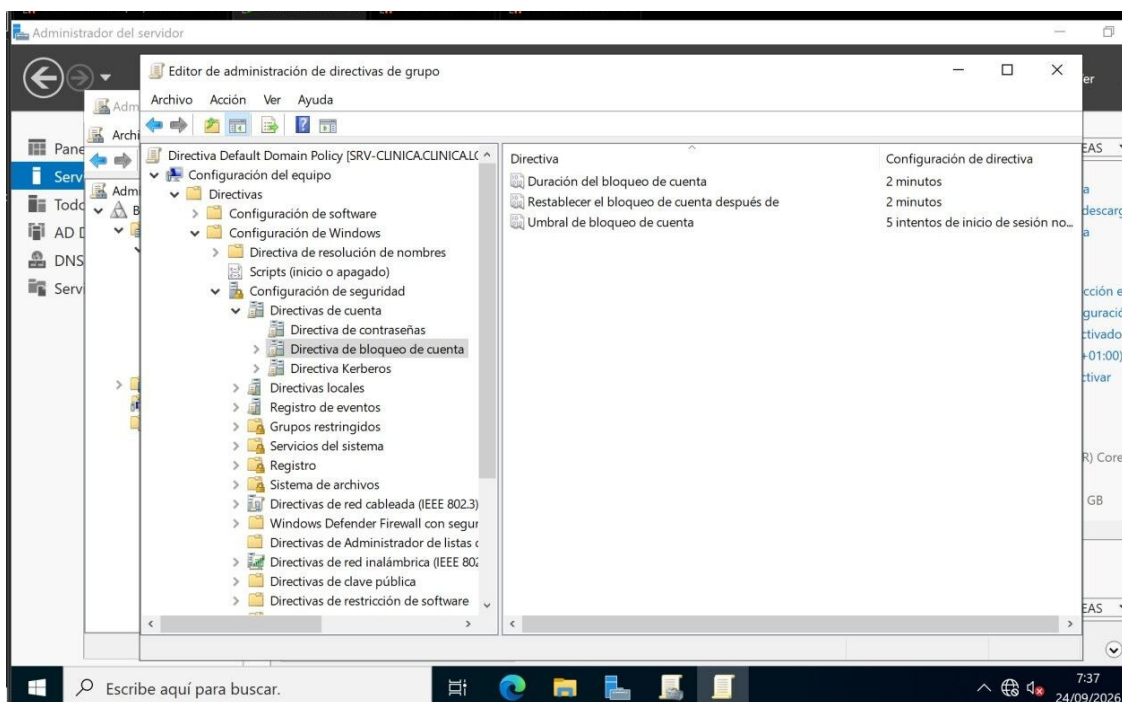


Figura 14. Directiva de bloqueo de cuenta: umbral de 5 intentos, duración y restablecimiento de 2 minutos.

2.7.4 Bloqueo automático de sesión (GPO_SEGURIDAD_CLINICA)

Se creó la GPO_SEGURIDAD_CLINICA vinculada a la OU CLINICA para activar el protector de pantalla protegido con contraseña. Después de 1 minuto de inactividad la sesión se bloquea y pide credenciales, evitando que otra persona use un equipo que quedó abierto. La política se aplicó con gpupdate /force y se verificó con gpresult /r.

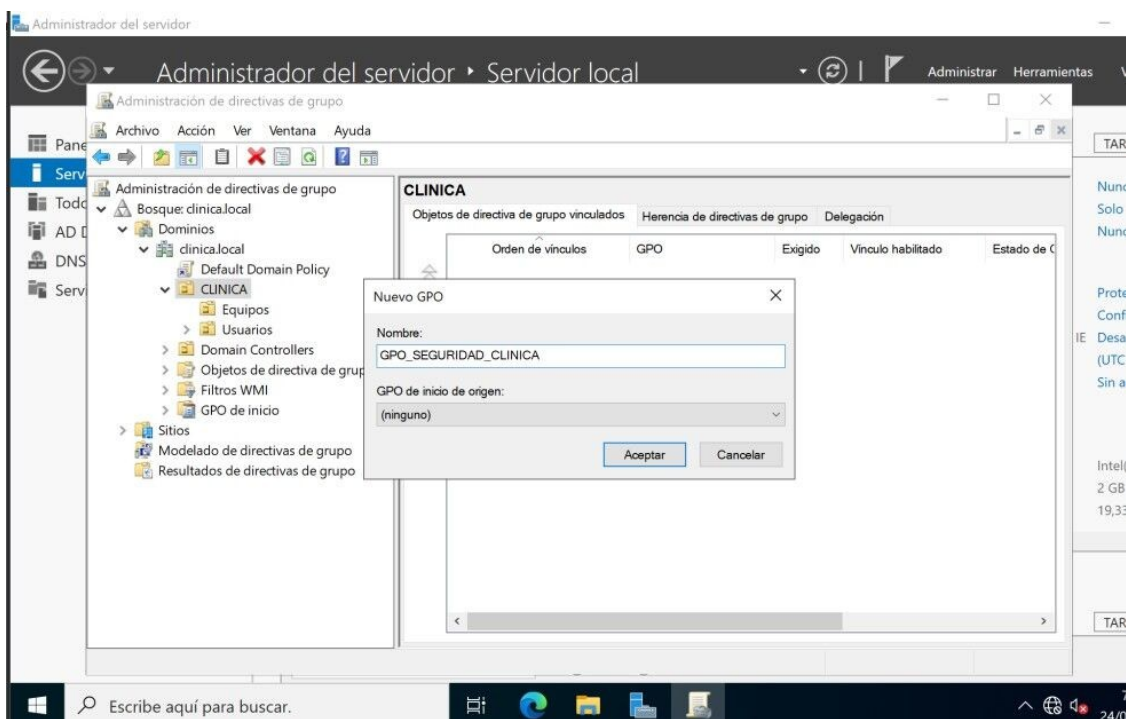


Figura 15. Creación de la GPO_SEGURIDAD_CLINICA vinculada a la OU CLINICA.

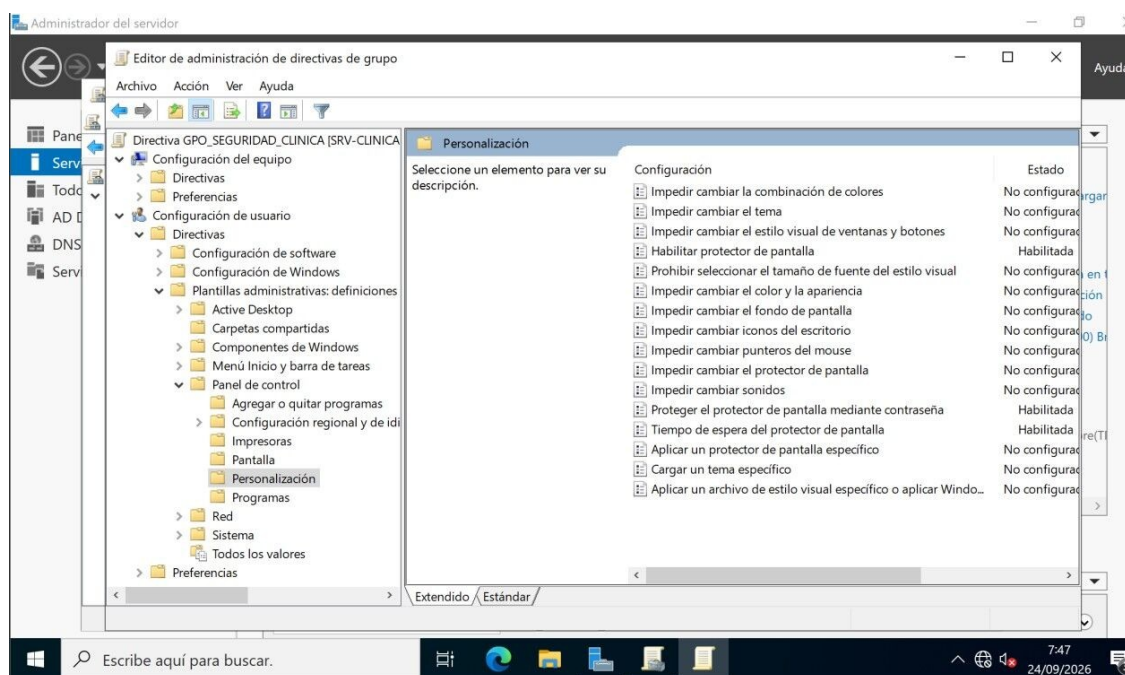


Figura 16. Configuración del protector de pantalla con contraseña y tiempo de espera.

2.7.5 Control de acceso a expedientes (NTFS y recurso compartido)

La carpeta `C:\CLINICA_DATOS\Expedientes` se compartió como `\\SRV-CLINICA\Expedientes`. Solo SYSTEM, Administradores y GG_MEDICOS tienen permisos; GG_MEDICOS tiene Modificar. Con medico01 se abren y modifican los expedientes; con recepcion01 Windows niega el acceso. Esto demuestra mínimo privilegio y confidencialidad.

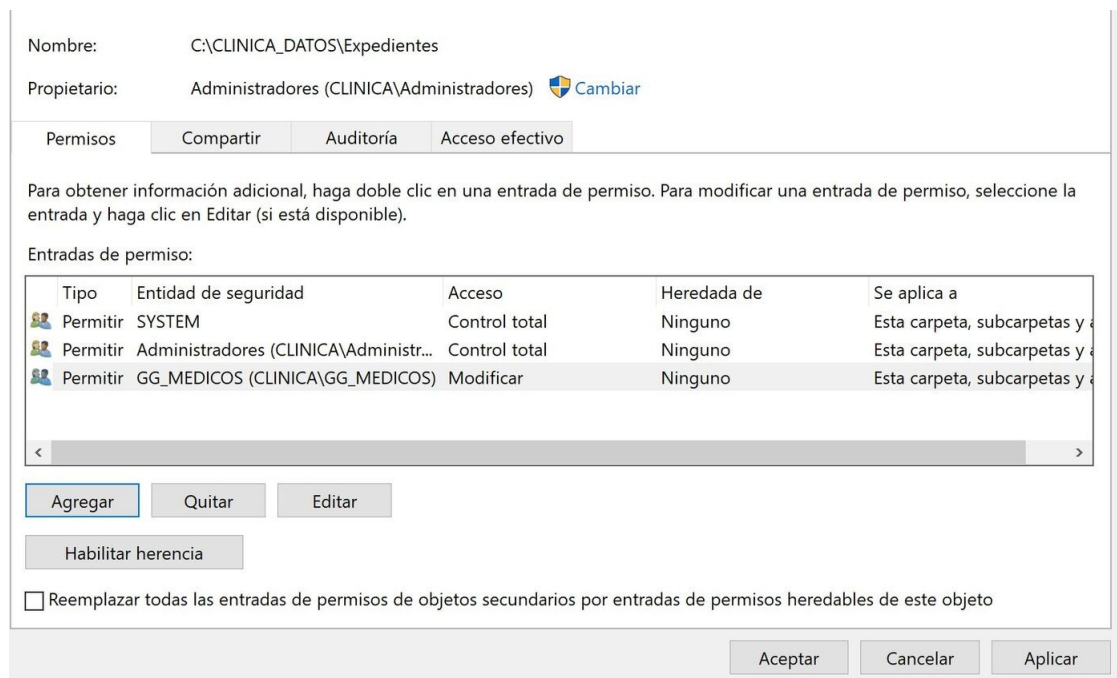


Figura 17. Permisos NTFS de la carpeta Expedientes: GG_MEDICOS con permiso Modificar.

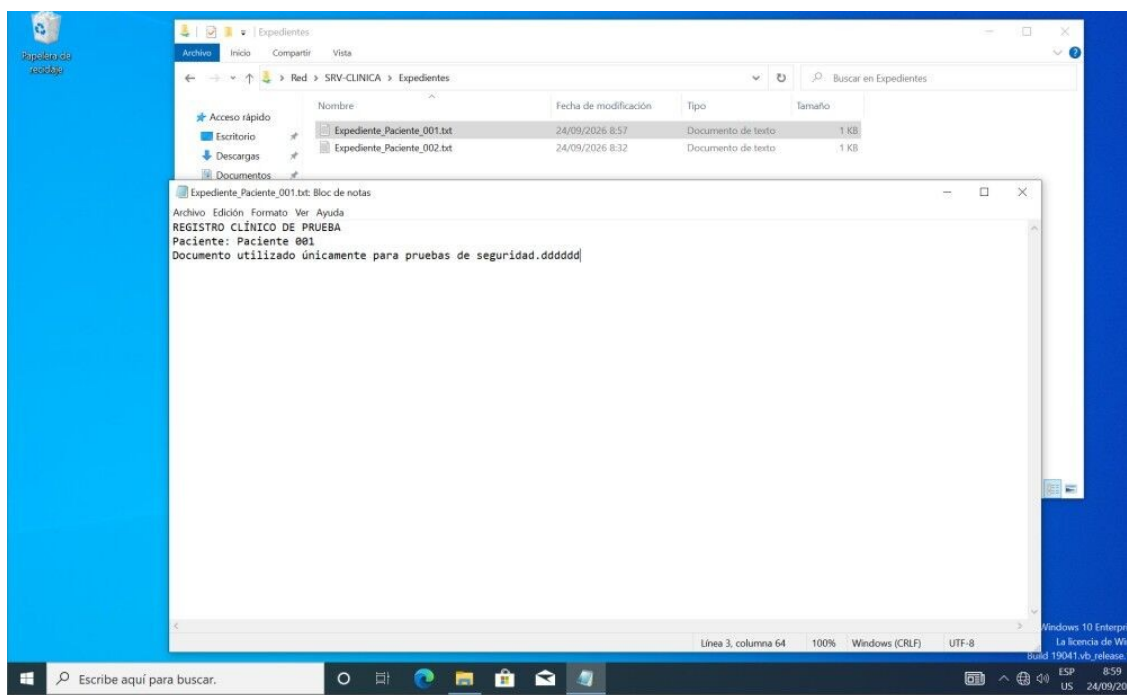


Figura 18. *medico01* abre y modifica *Expediente_Paciente_001* desde *PC-MEDICO*.

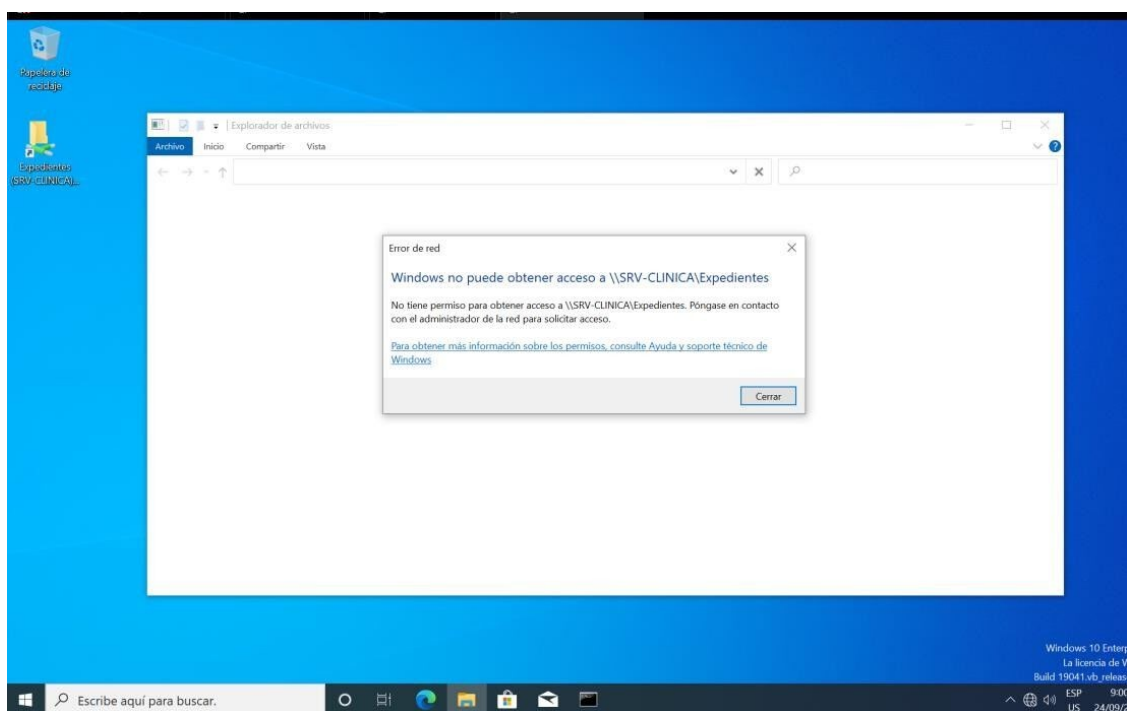


Figura 19. *recepcion01* recibe «Windows no puede obtener acceso a \\\SRV-CLINICA\Expedientes».

2.7.6 Auditoría de acceso a objetos (eventos 4663)

Se habilitó la auditoría del sistema de archivos (correcto y error) mediante GPO y se agregó una entrada de auditoría (SACL) sobre Expedientes para GG_RECEPCION. Cuando *recepcion01* intenta entrar, el servidor registra el evento 4663 con el usuario, el dominio, el objeto y la hora. También se audió a *medico01* para registrar las modificaciones que hace sobre los expedientes.

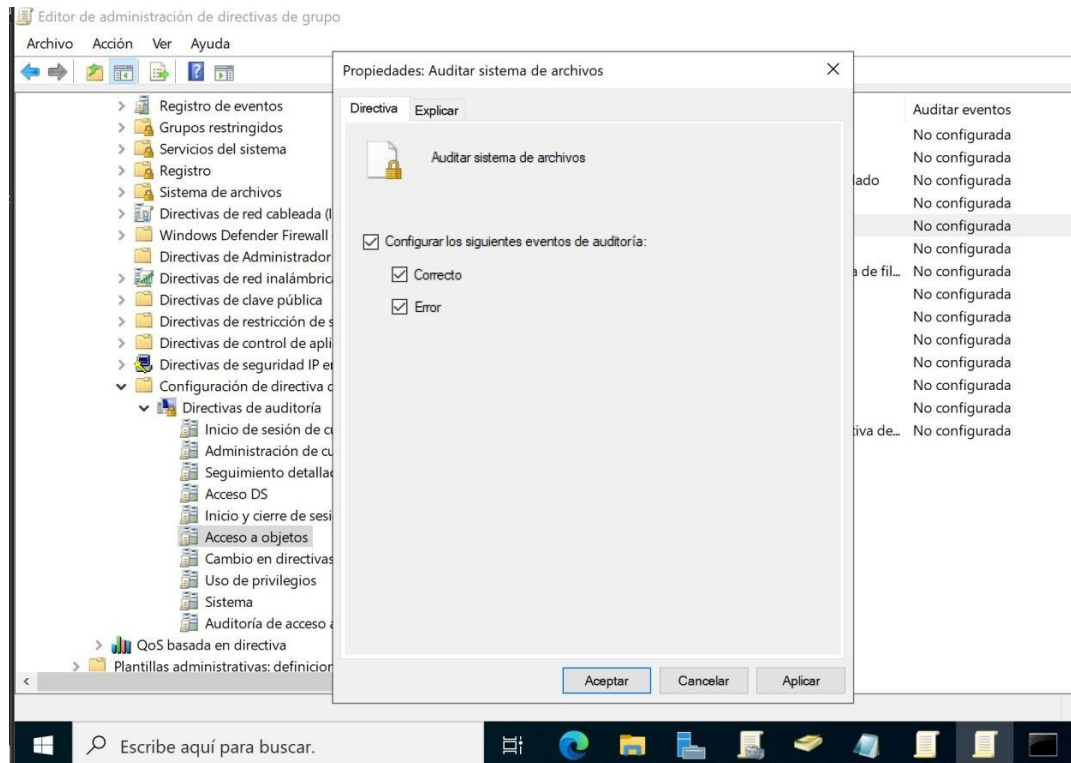


Figura 20. GPO de auditoría: Auditar sistema de archivos con eventos correctos y erróneos.

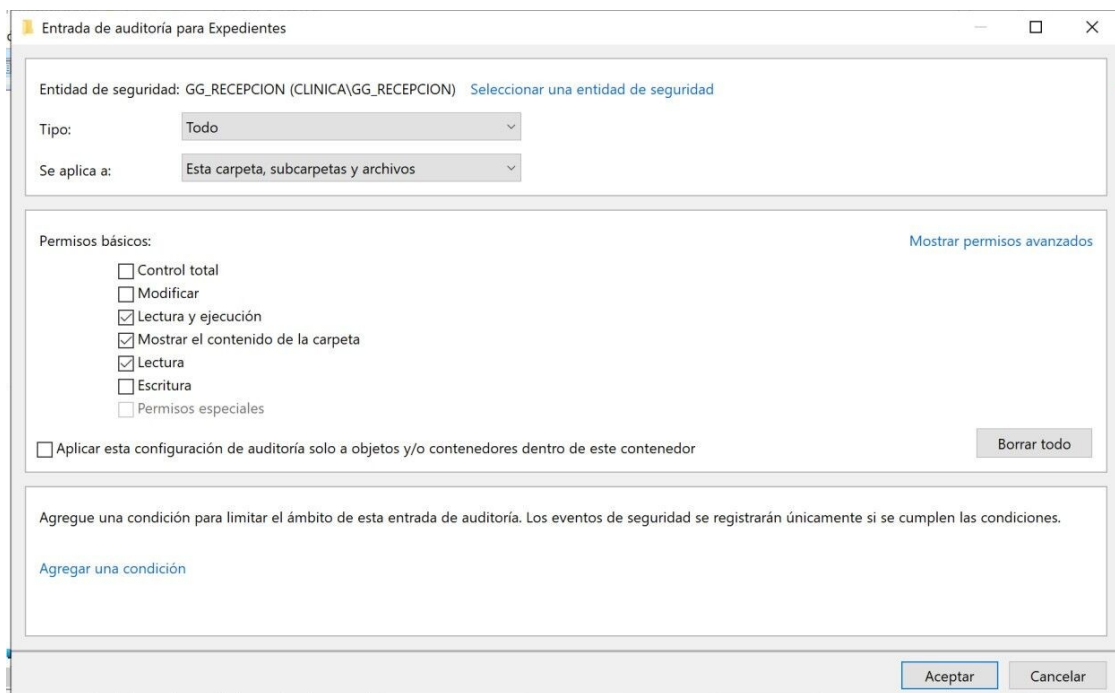


Figura 21. Entrada de auditoría sobre Expedientes para GG_RECEPCION.

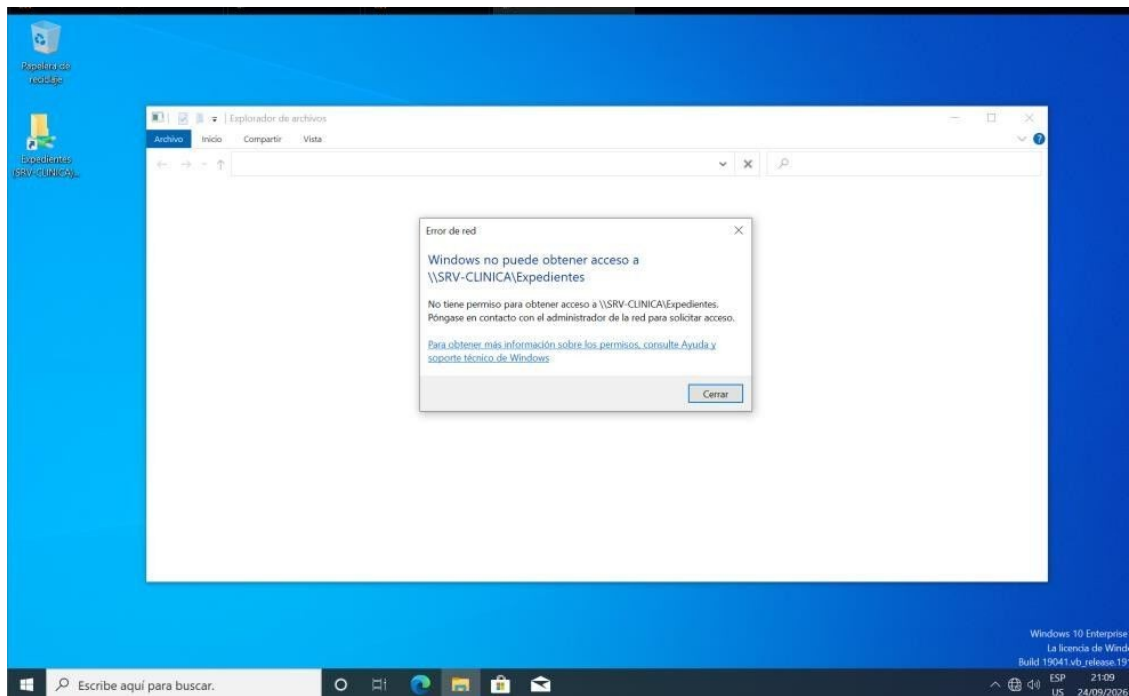


Figura 22. Intento de acceso de recepcion01 a \\SRV-CLINICA\Expedientes (denegado).

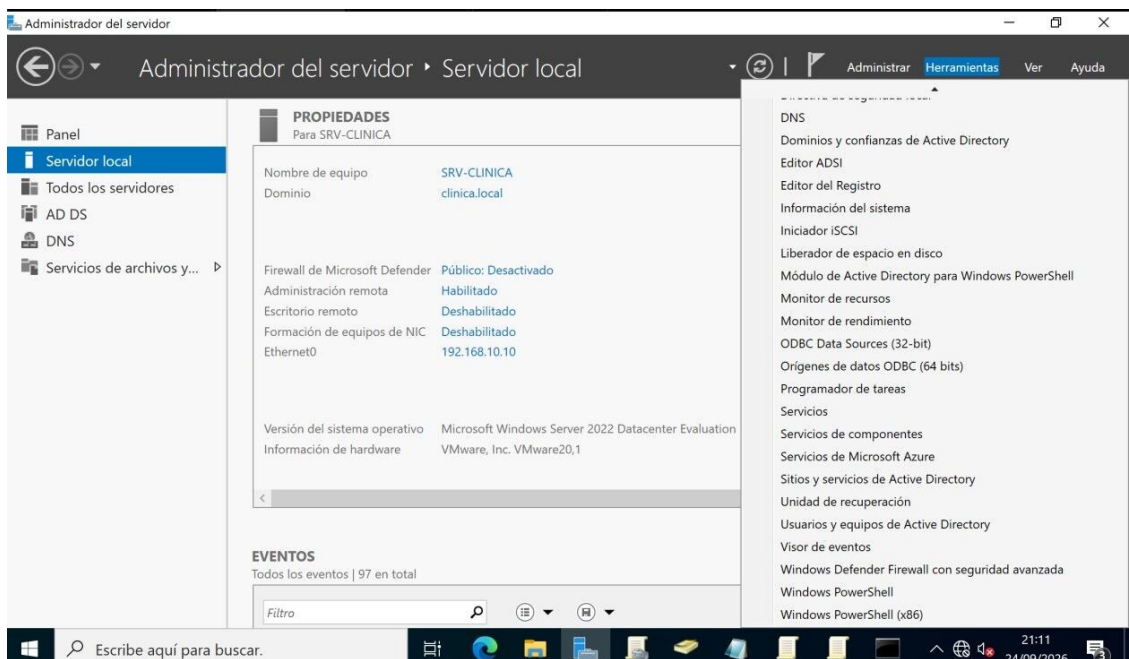


Figura 23. Acceso al Visor de eventos desde el Administrador del servidor.

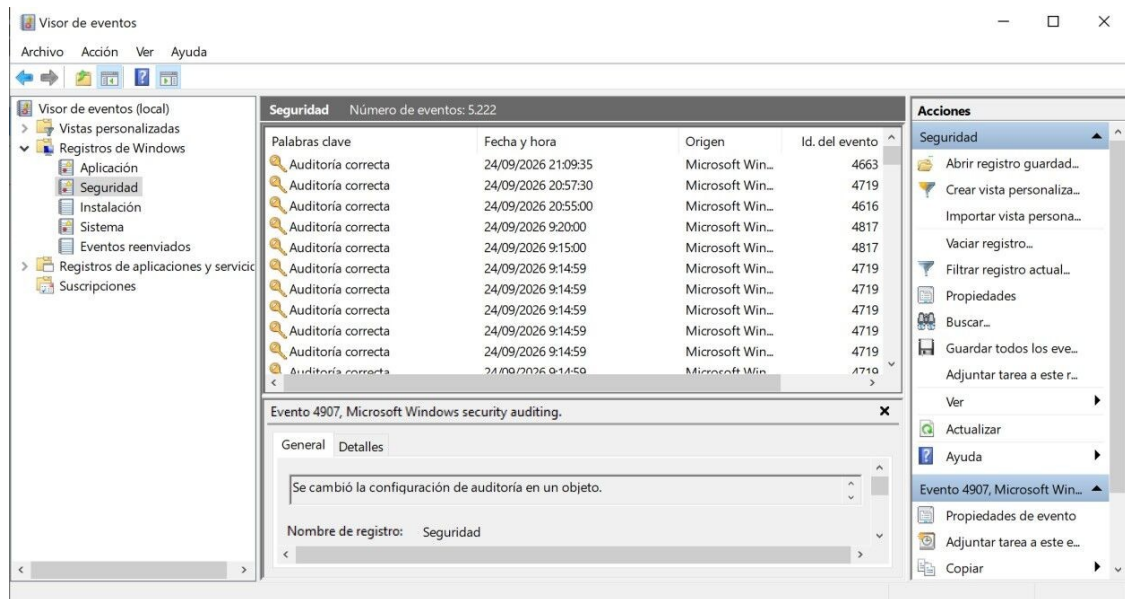


Figura 24. Registro de Seguridad con los eventos de auditoría generados.

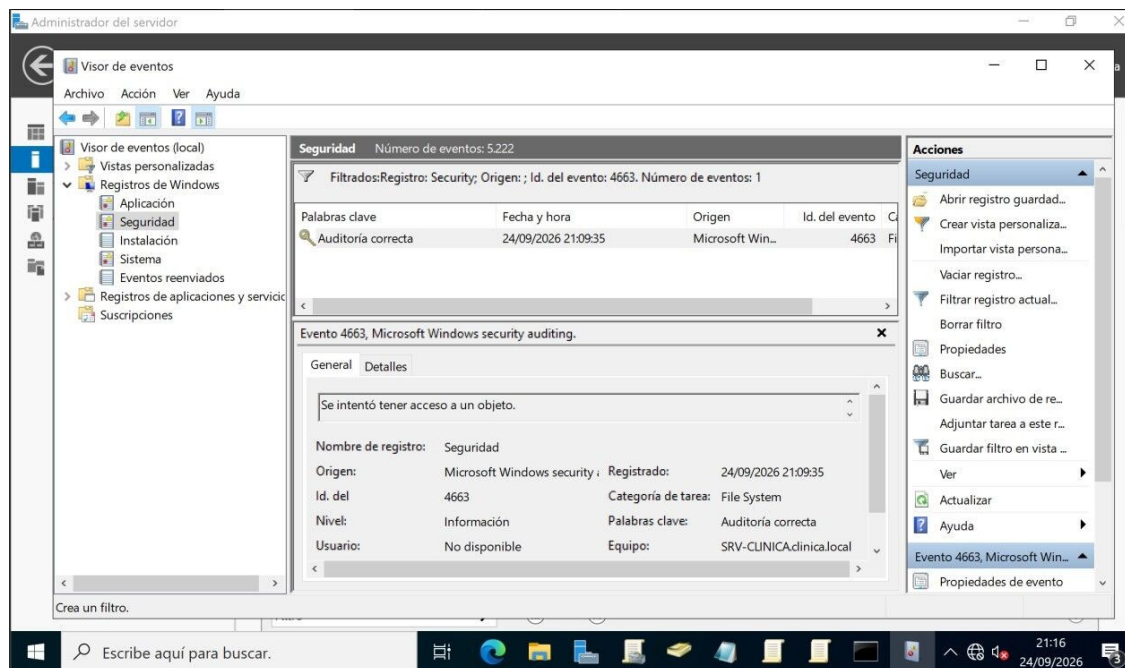


Figura 25. Filtro por Id. de evento 4663.

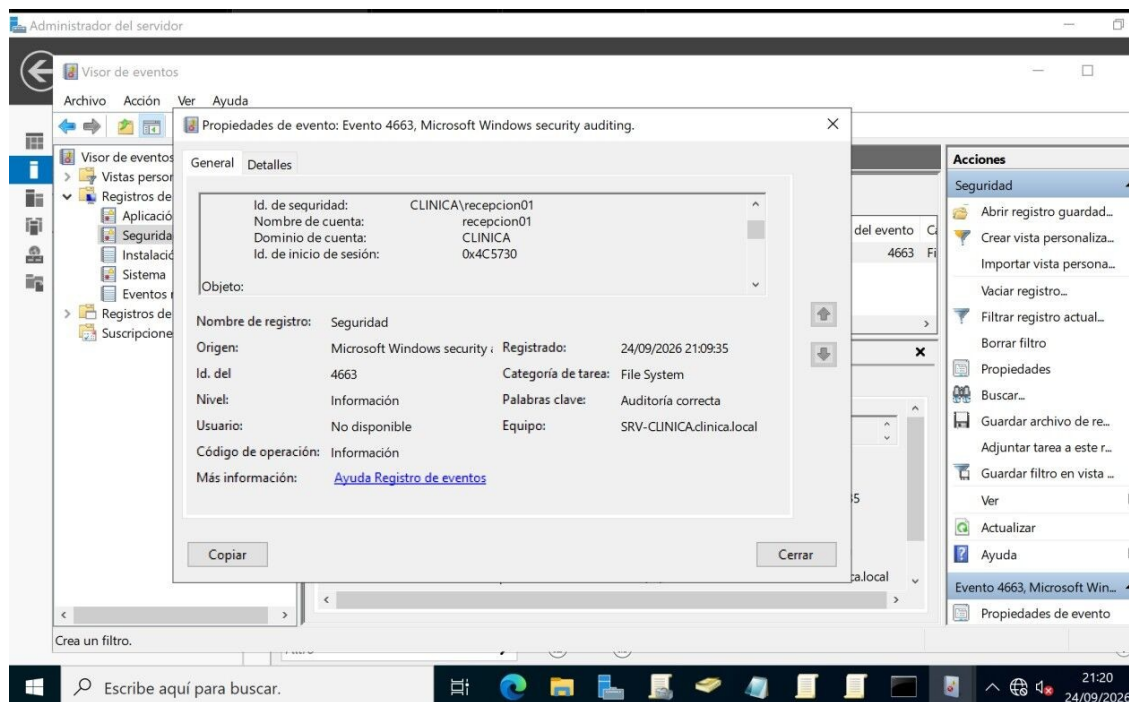


Figura 26. Evento 4663: CLINICA\recepcion01 intentó acceder a un objeto del sistema de archivos.

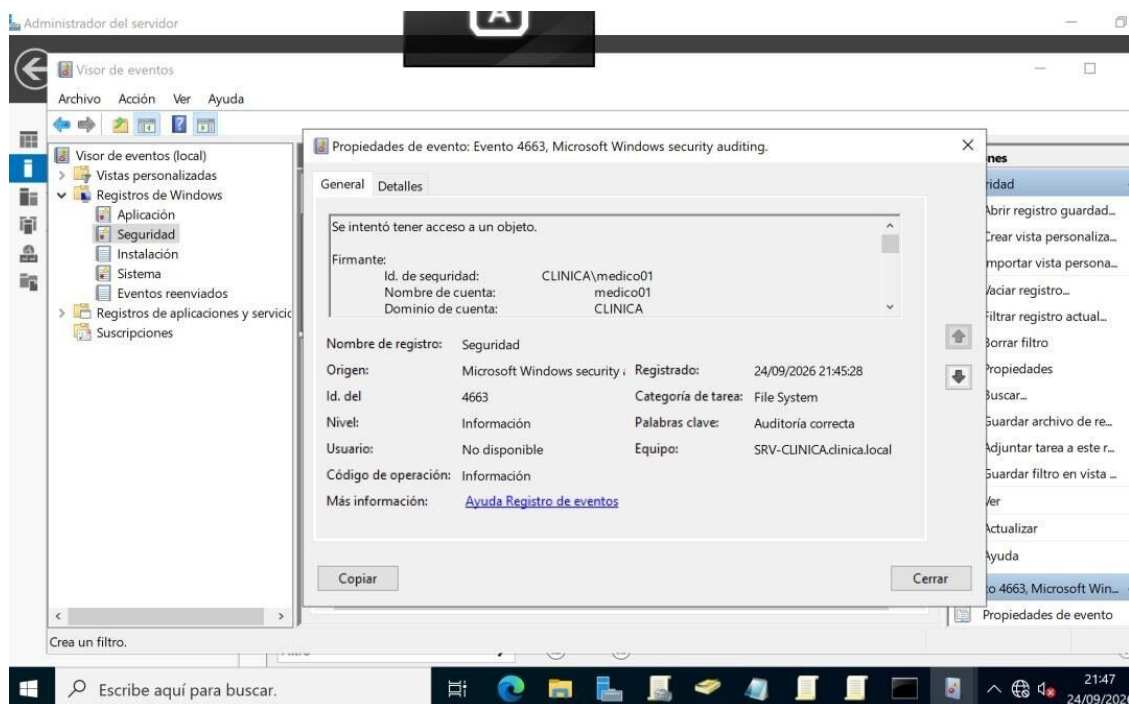


Figura 27. Evento 4663: acceso de CLINICA\medico01 al expediente, registrado para trazabilidad.

2.7.7 Auditoría de bloqueo de cuentas (evento 4740)

En la GPO_AUDITORIA_SERVIDOR se activó la auditoría de administración de cuentas. Al superar el umbral de intentos fallidos la cuenta medico01 quedó bloqueada y el servidor registró el evento 4740 indicando la cuenta, el equipo de origen (PC-MEDICO) y la hora.

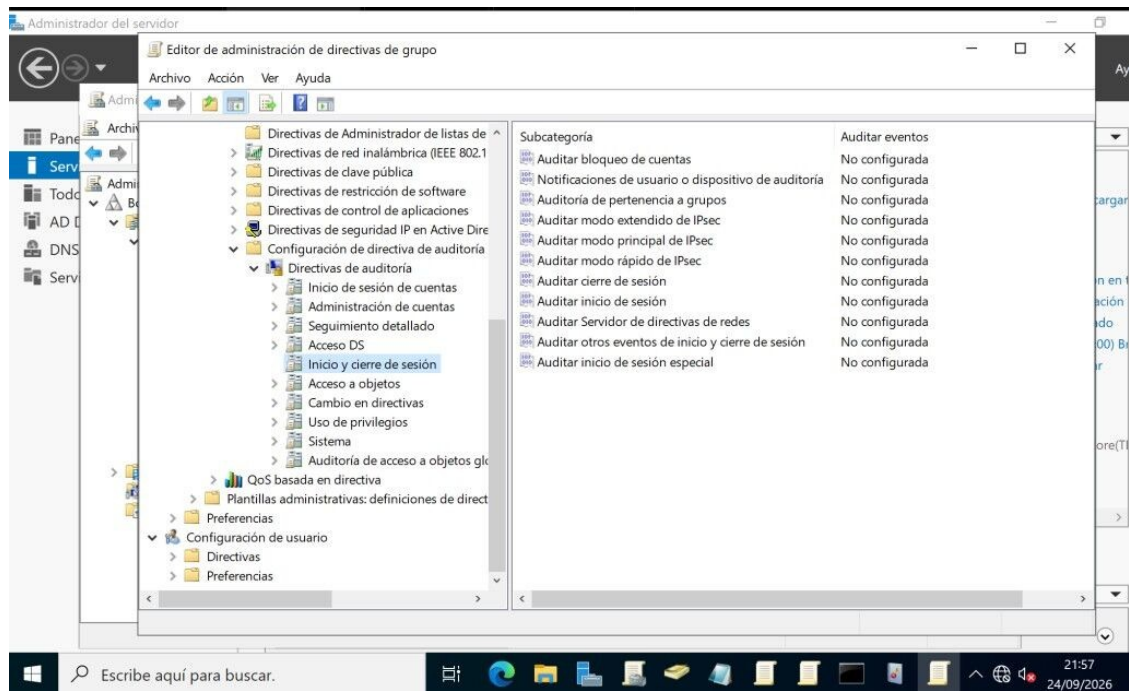


Figura 28. Configuración de la directiva de auditoría avanzada en GPO_AUDITORIA_SERVIDOR.

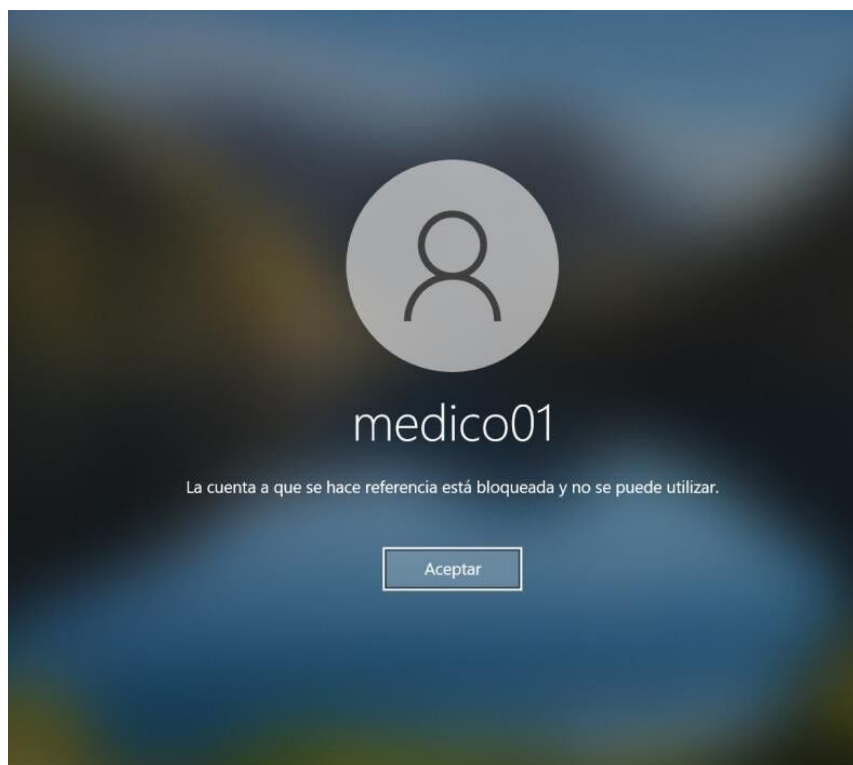


Figura 29. PC-MEDICO: «La cuenta a que se hace referencia está bloqueada y no se puede utilizar».

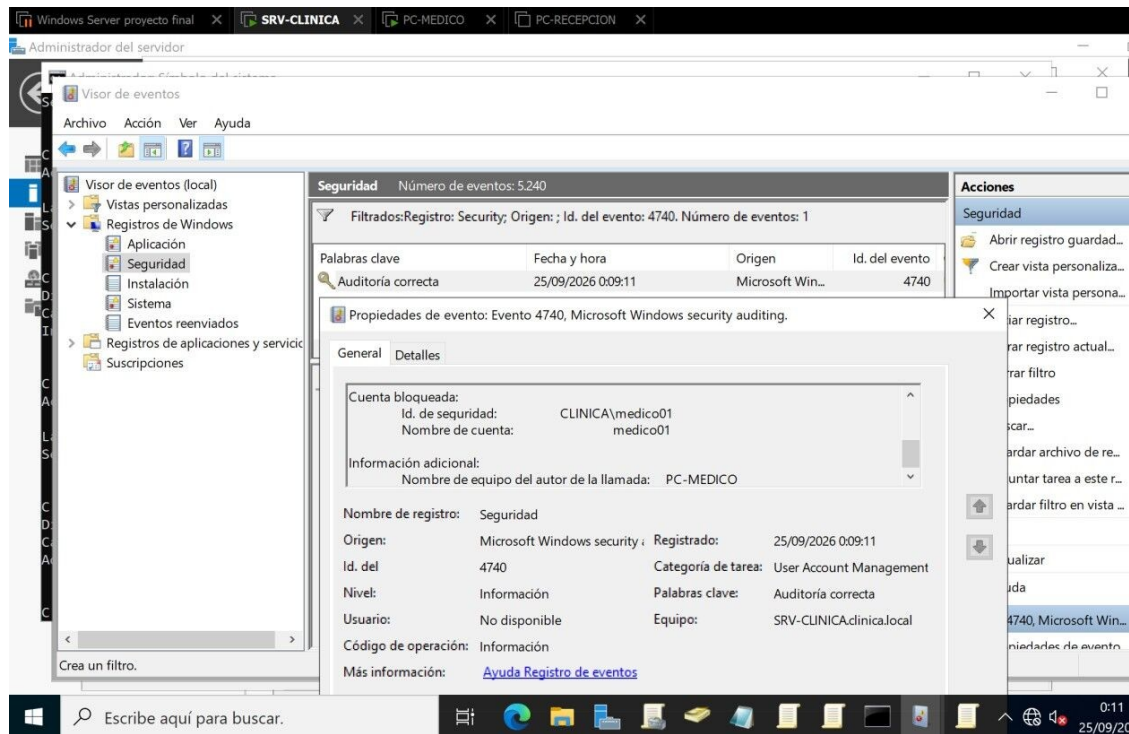


Figura 30. Evento 4740: bloqueo de CLINICA\medico01, equipo de origen PC-MEDICO.

2.7.8 Auditoría de cambios en grupos de seguridad (evento 4728)

Se agregó un usuario de prueba al grupo GG_MEDICOS. El servidor registró el evento 4728, que muestra qué administrador hizo el cambio, qué miembro se agregó y a qué grupo. Con esto queda evidencia de cualquier cambio de privilegios.

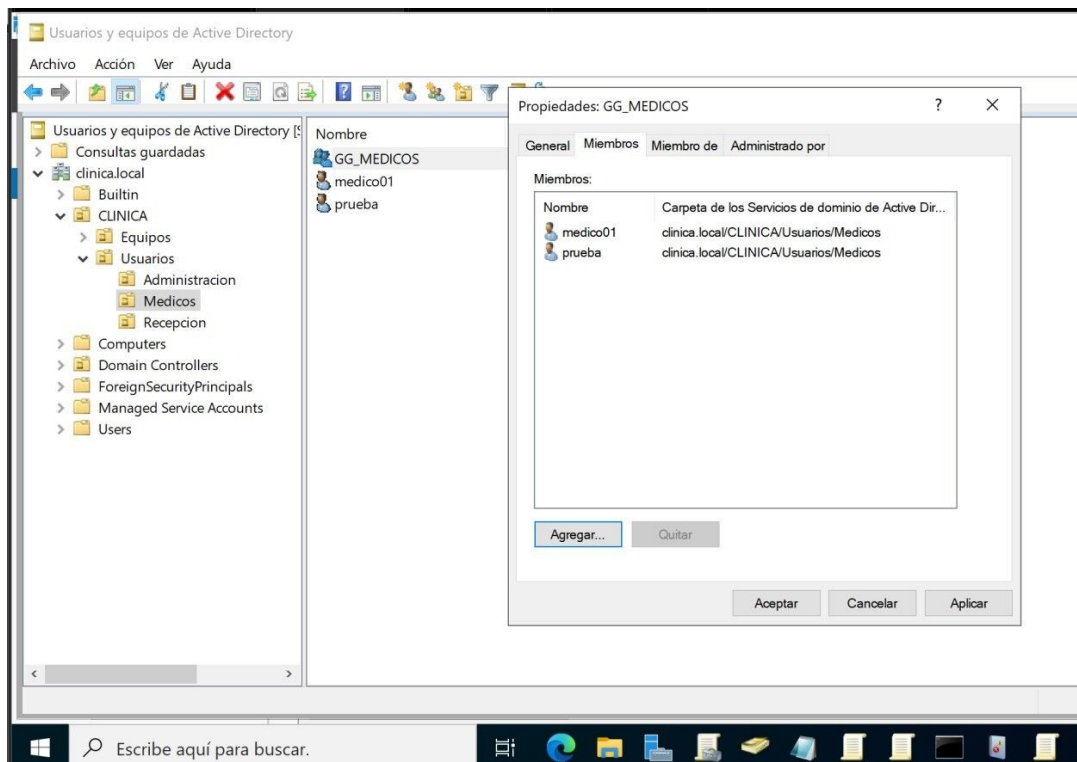


Figura 31. Se agrega el usuario «prueba» al grupo GG_MEDICOS.

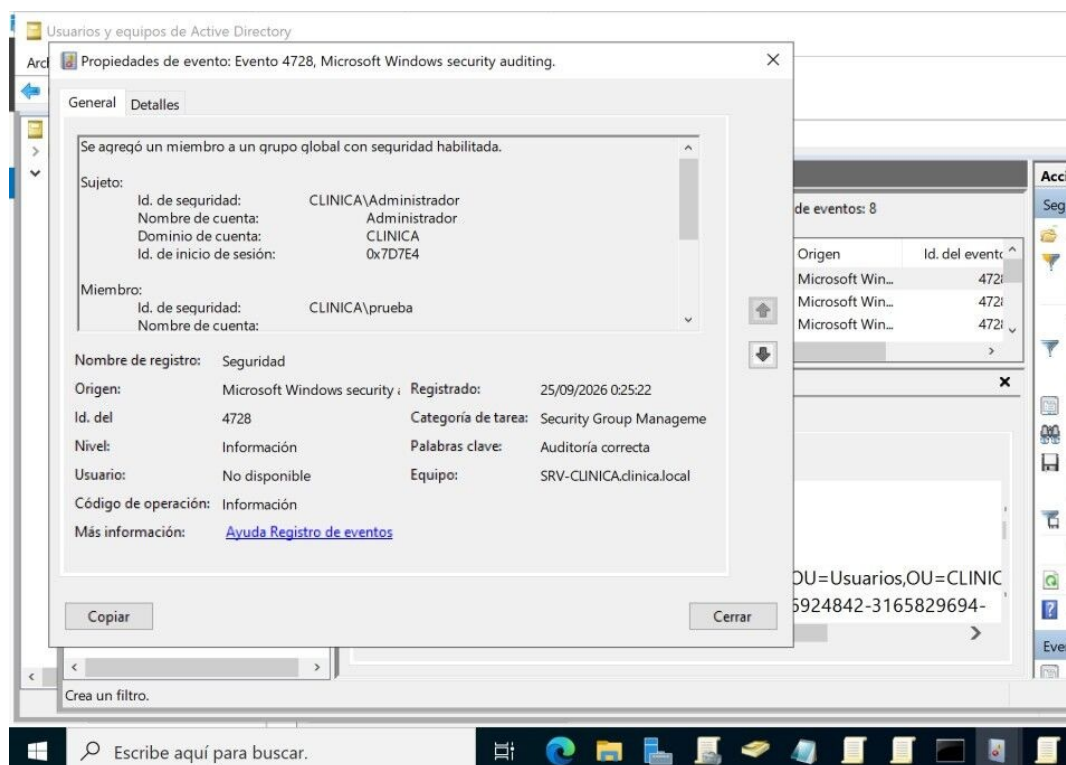


Figura 32. Evento 4728: CLINICA\Administrador agregó a CLINICA\prueba a un grupo global de seguridad.

2.7.9 Respaldo y recuperación con Windows Server Backup

Se instaló la característica Copias de seguridad de Windows Server y se agregó un segundo disco (BACKUP_CLINICA) dedicado a los respaldos. Se respaldó la carpeta CLINICA_DATOS, luego se borró un expediente desde PC-MEDICO y se recuperó desde la copia. El archivo volvió a su ubicación original, lo que prueba la disponibilidad y la continuidad de la información.

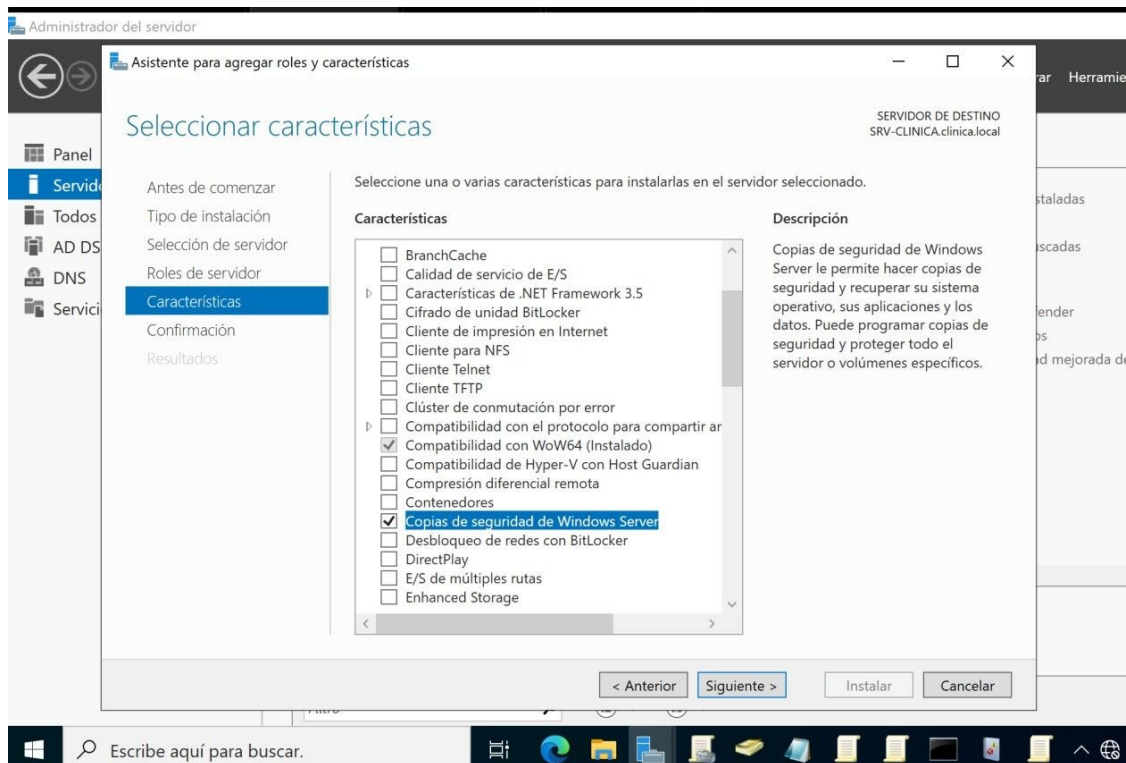


Figura 33. Instalación de la característica Copias de seguridad de Windows Server.

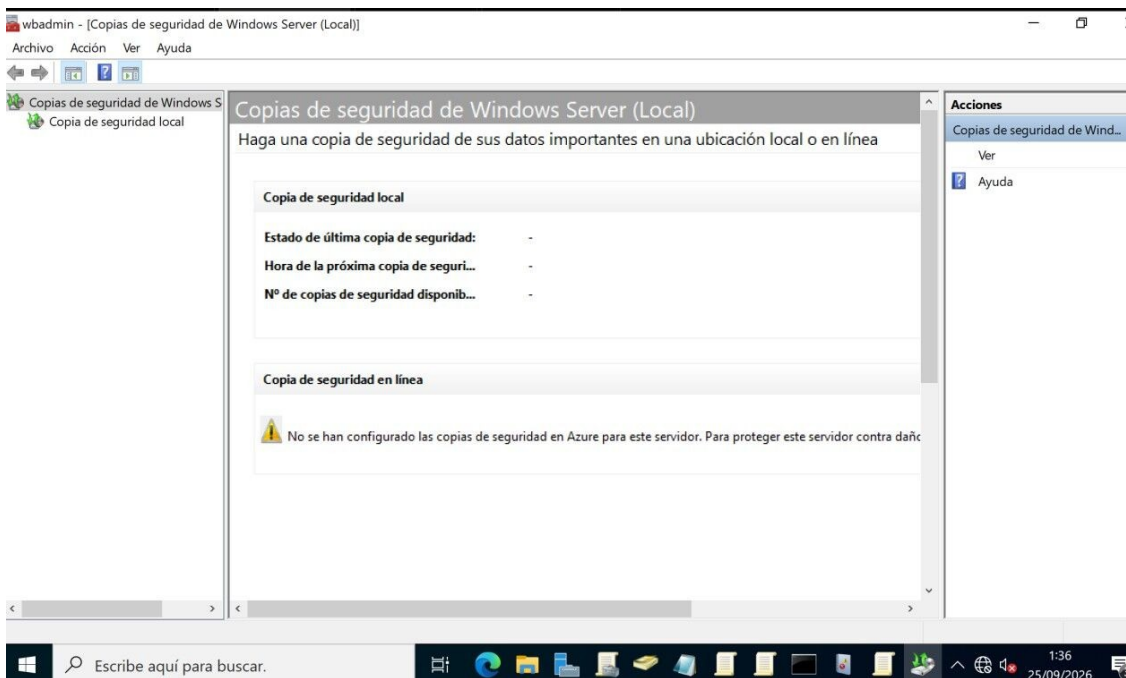


Figura 34. Consola wbadmin sin copias configuradas.

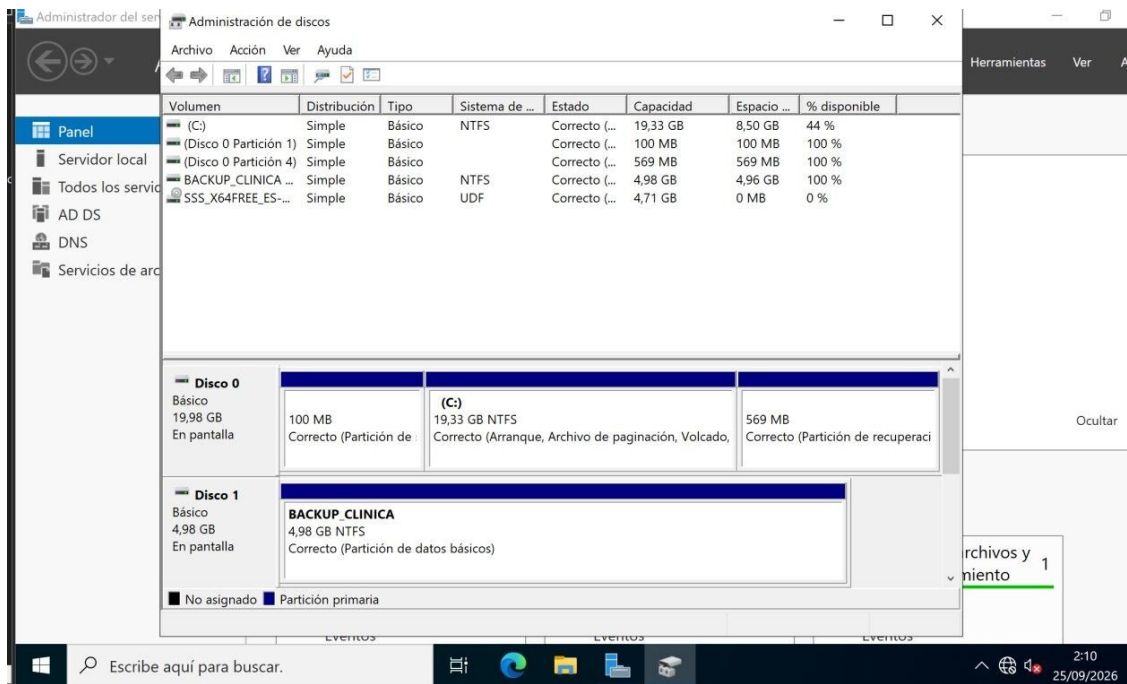


Figura 35. Disco 1 dedicado BACKUP_CLINICA (NTFS) para almacenar los respaldos.

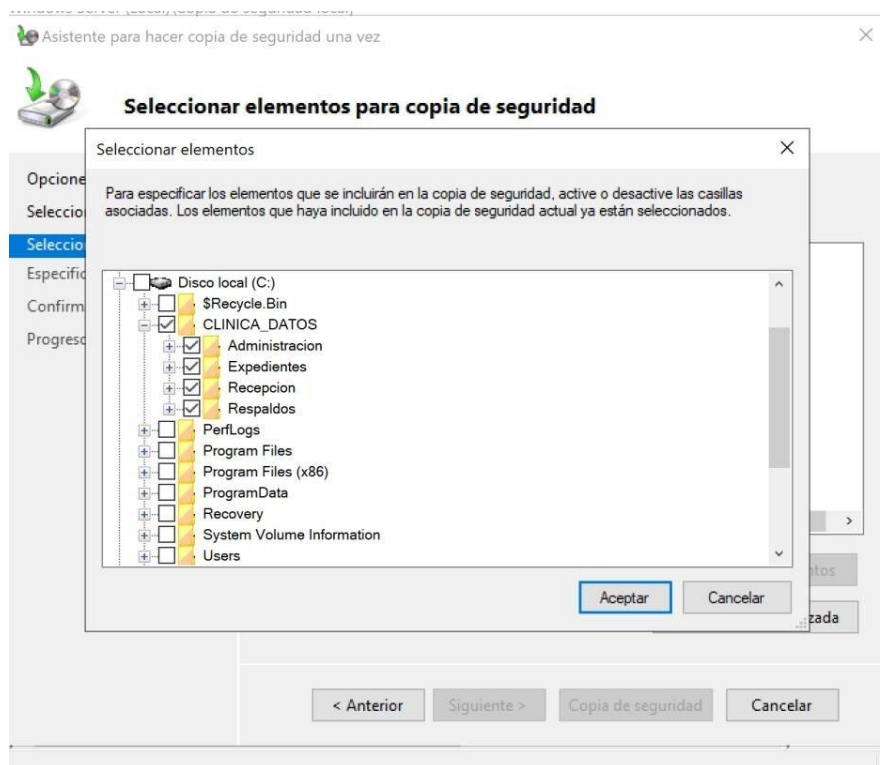


Figura 36. Selección de CLINICA_DATOS (Administracion, Expedientes, Recepcion, Respaldos).

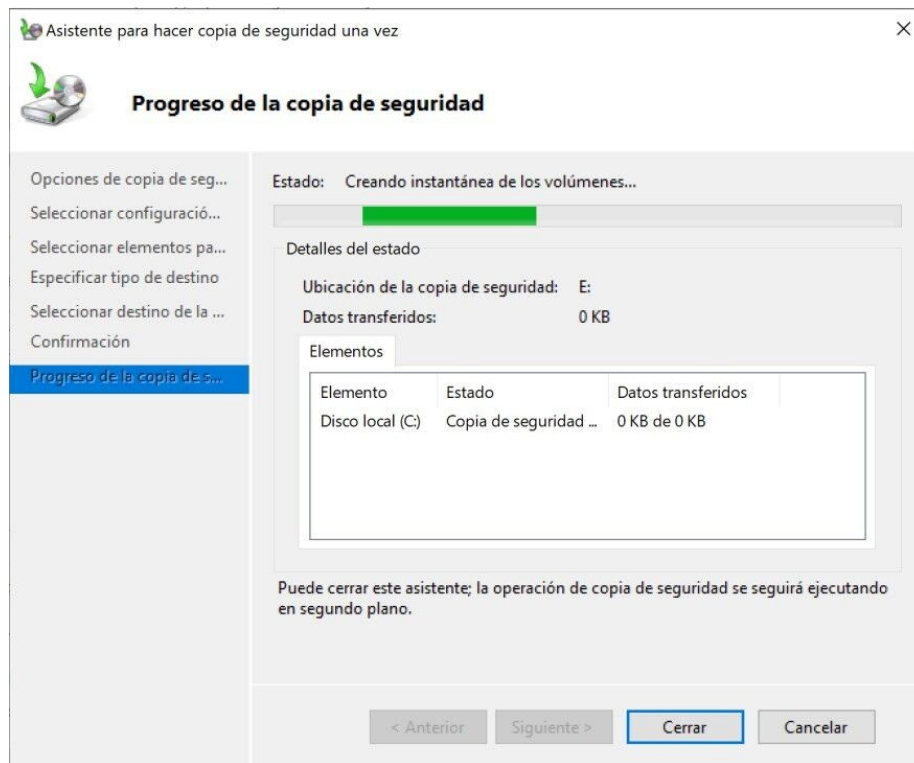


Figura 37. Progreso de la copia de seguridad.

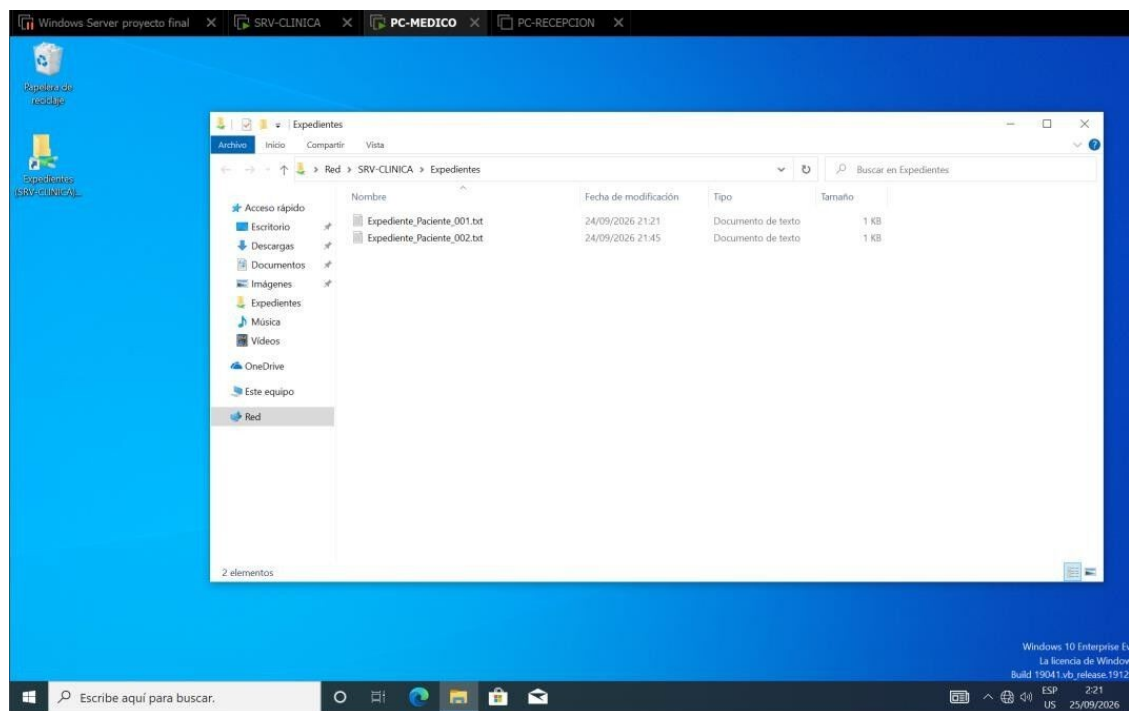


Figura 38. Desde PC-MEDICO se elimina un expediente de forma intencional.

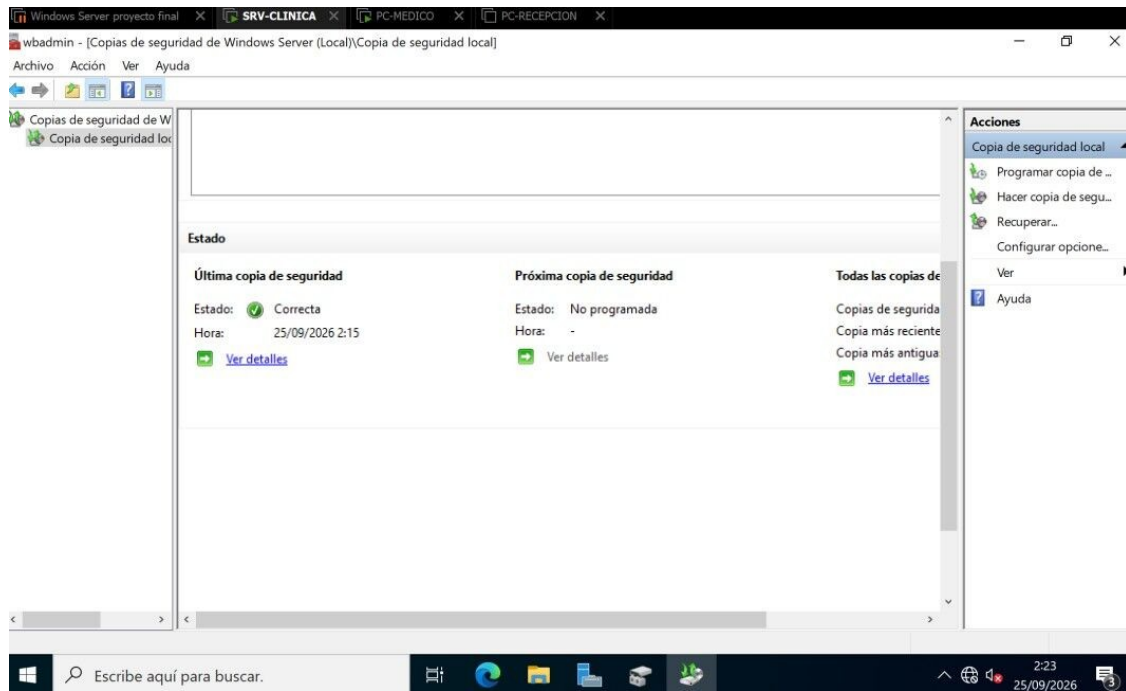


Figura 39. Copia de seguridad completada correctamente.

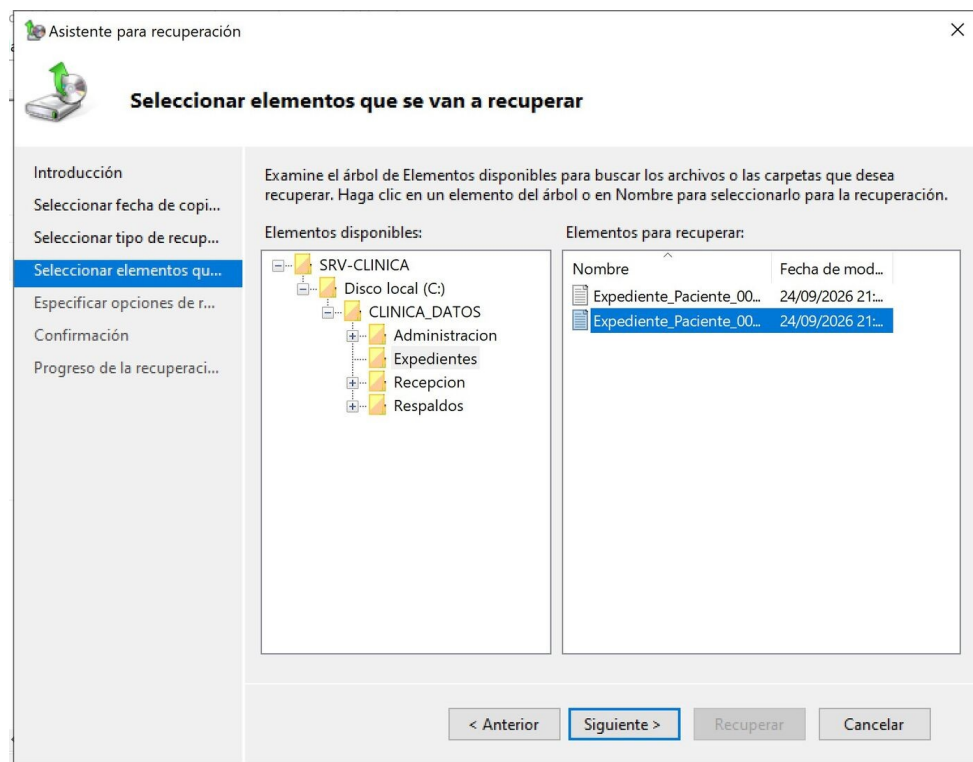


Figura 40. Asistente de recuperación: selección del expediente eliminado.

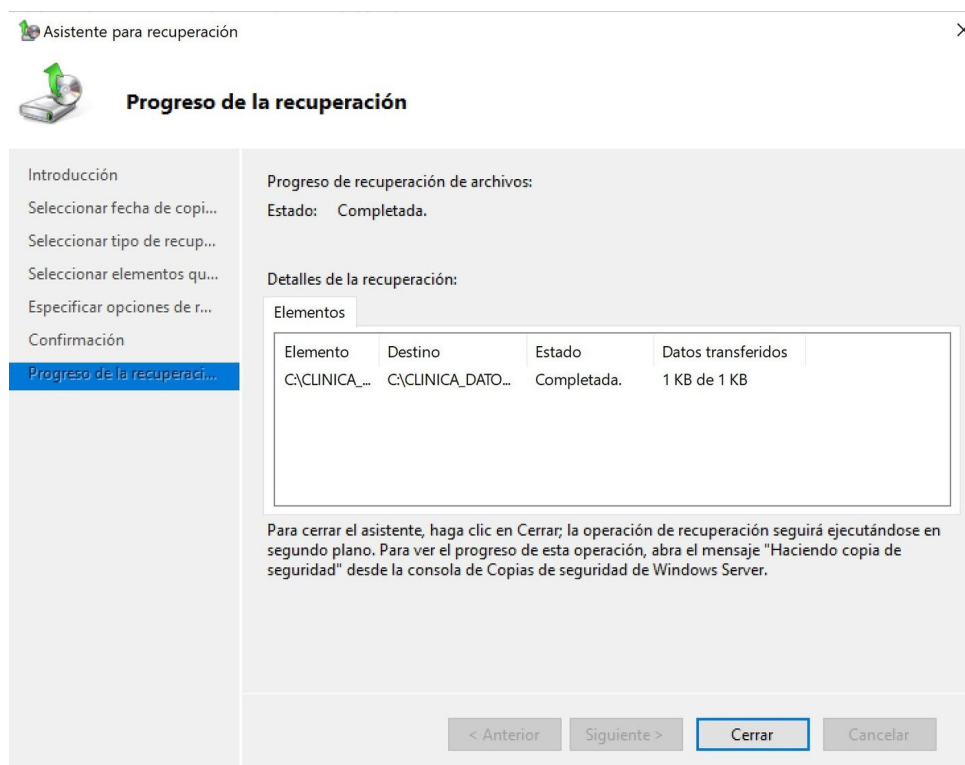


Figura 41. Recuperación completada.

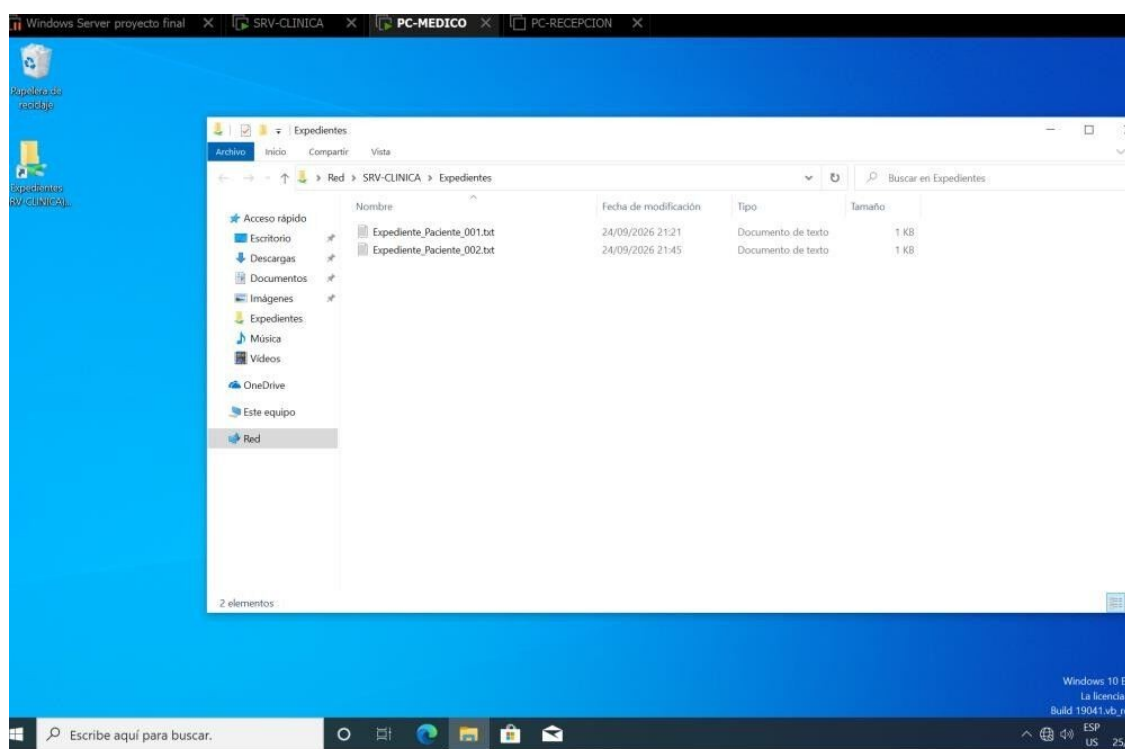


Figura 42. El expediente vuelve a aparecer en \\SRV-CLINICA\Expedientes.

2.7.10 Resumen de eventos auditables

Id. evento	Qué registra	Prueba realizada
4663	Intento de acceso a un objeto (archivo o carpeta)	repcion01 intenta abrir Expedientes; medico01 modifica un expediente
4740	Bloqueo de una cuenta de usuario	medico01 supera el umbral de intentos

Id. evento	Qué registra	Prueba realizada
		desde PC-MEDICO
4728	Miembro agregado a un grupo global de seguridad	Administrador agrega «prueba» a GG_MEDICOS
4907	Cambio en la configuración de auditoría de un objeto	Configuración de la SACL de Expedientes

Conclusiones y recomendaciones

Conclusiones

1. Se implementó un modelo de seguridad funcional para la Clínica Médica Vida Segura sobre un dominio de Windows Server, cubriendo los tres pilares de la tríada CIA.
2. La autenticación centralizada y el uso de grupos por rol permitieron aplicar el principio de mínimo privilegio: el médico accede a los expedientes y la recepción no.
3. El modelo es auditable. Los eventos 4663, 4740 y 4728 identifican al usuario, la acción, el objeto, el equipo y la hora, lo que permite reconstruir cualquier incidente.
4. La prueba de borrado y recuperación demostró que los expedientes pueden restaurarse a partir del respaldo, lo que protege la disponibilidad ante errores o ataques.
5. Usar ISO/IEC 27001/27002 como referencia dio orden al proyecto y facilita que en el futuro la clínica avance hacia un sistema de gestión de seguridad formal.

Recomendaciones

- Programar respaldos diarios y mantener una copia fuera del servidor (regla 3-2-1), por ejemplo en un disco externo o en la nube.
- Aumentar la longitud mínima de contraseña a 12 caracteres y evaluar la autenticación multifactor para cuentas administrativas.
- Implementar el firewall perimetral (pfSense) y segmentar la red en VLAN para servidores, consultorios y administración, tal como se propuso en el segundo entregable.
- Centralizar y conservar los registros de seguridad (por ejemplo, con reenvío de eventos o un SIEM) y revisarlos periódicamente.
- Agregar un segundo controlador de dominio para evitar un único punto de falla.
- Capacitar al personal y formalizar las políticas de seguridad con la aprobación de la administración de la clínica.

Glosario

Término	Definición
Active Directory (AD DS)	Servicio de directorio de Microsoft que centraliza usuarios, equipos, grupos y políticas de un dominio.
Auditoría	Registro y revisión de eventos para verificar el cumplimiento de controles y detectar incidentes.
Controlador de dominio	Servidor que autentica a los usuarios y equipos del dominio y aplica sus políticas.
DNS	Sistema que traduce nombres (clinica.local) a direcciones IP.
GPO	Objeto de directiva de grupo; conjunto de configuraciones que se aplican automáticamente a usuarios y equipos.
ISO/IEC 27001	Norma internacional que define los requisitos de un sistema de gestión de seguridad de la información.
ISO/IEC 27002	Guía de controles de seguridad de la información que complementa a ISO/IEC 27001.
Mínimo privilegio	Principio según el cual cada usuario solo tiene los permisos necesarios para su trabajo.
NTFS	Sistema de archivos de Windows que permite asignar permisos a carpetas y archivos.
OU	Unidad organizativa; contenedor de Active Directory para ordenar usuarios, grupos y equipos.
OVA	Archivo que empaqueta una máquina virtual completa para exportarla e importarla.
RBAC	Control de acceso basado en roles.
Ransomware	Software malicioso que cifra la información y exige un pago para liberarla.
SACL	Lista de control de acceso del sistema; define qué accesos a un objeto se auditan.
Tríada CIA	Confidencialidad, integridad y disponibilidad: los tres pilares de la seguridad de la información.
VMware	Software de virtualización que permite ejecutar varias máquinas virtuales en un equipo físico.

Bibliografía

- International Organization for Standardization. (2022). ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements. ISO.
- International Organization for Standardization. (2022). ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection — Information security controls. ISO.
- National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0. <https://doi.org/10.6028/NIST.CSWP.29>
- National Institute of Standards and Technology. (2020). Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev. 5). <https://doi.org/10.6028/NIST.SP.800-53r5>
- Microsoft. (s. f.). Active Directory Domain Services overview. Microsoft Learn. <https://learn.microsoft.com/windows-server/identity/ad-ds/get-started/virtual-dc/active-directory-domain-services-overview>
- Microsoft. (s. f.). 4663(S): An attempt was made to access an object. Microsoft Learn. <https://learn.microsoft.com/windows/security/threat-protection/auditing/event-4663>
- Microsoft. (s. f.). 4740(S): A user account was locked out. Microsoft Learn. <https://learn.microsoft.com/windows/security/threat-protection/auditing/event-4740>
- Microsoft. (s. f.). 4728(S): A member was added to a security-enabled global group. Microsoft Learn. <https://learn.microsoft.com/windows/security/threat-protection/auditing/event-4728>
- Microsoft. (s. f.). Windows Server Backup overview. Microsoft Learn. <https://learn.microsoft.com/windows-server/administration/windows-server-backup/windows-server-backup-overview>
- Stallings, W. y Brown, L. (2018). Computer Security: Principles and Practice (4.^a ed.). Pearson.

Anexo. Acceso al proyecto virtualizado

Recurso	Enlace
Sitio del proyecto (GitHub Pages)	https://USUARIO.github.io/clinica-vida-segura/
Máquinas virtuales exportadas (.OVA)	https://drive.google.com/... (pegar enlace de la carpeta)
Video de demostración	https://youtu.be/... (pegar enlace)

Credenciales de laboratorio: dominio CLINICA · medico01 / Medico432 · recepcion01 / Recepcion432 · Admin01 / Admin432.